CASE STUDY

The Year 2025 in Intrusions: A Dated Record

A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.

Executive summary

For the people who defend networks, 2025 was the year the trusted connection became the way in. The edge appliance kept falling: Ivanti Connect Secure gateways were exploited as zero-days twice, a FortiOS authentication bypass was exploited in the wild and listed in KEV the day Fortinet confirmed it, and by autumn CISA had issued three emergency directives in ten weeks, for a Microsoft Exchange hybrid flaw, for Cisco firewalls whose read-only memory an actor had altered to survive reboots, and for F5 after a nation-state actor walked out with part of the BIG-IP source code. The second door was the integration nobody watched: voice phishers talked staff, including call-centre workers, into authorizing a modified data-loading app in Salesforce, a separate actor used stolen OAuth tokens from a chat integration to export data from numerous Salesforce tenants, a backup vendor's cloud client secrets may have been taken, and a cryptocurrency exchange paid nothing to an extortionist who had paid its overseas support contractors or employees for data. The third door was the build pipeline: a compromised GitHub Action spilled secrets into public build logs, an AI coding extension shipped a release carrying an outsider's code, and a self-replicating worm moved through more than 500 npm packages and came back in November with a destructive fallback. The single largest theft was not ransomware at all: the FBI attributes the loss of about US$1.5 billion from the Bybit exchange to North Korea. Governments answered with emergency directives, sanctions on Chinese companies, bulletproof hosts and a crypto exchange, takedowns of Lumma and the droppers of Operation Endgame, charges against Chinese contract hackers and a UK national alleged to be part of Scattered Spider, a UK plan to ban public-sector ransom payments and a UN convention opened for signature.

This study is the dated record of that year. It is a chronicle, not a deep dive: where another study in this series is the home for an event, this one gives a paragraph and a link. SharePoint ToolShell is told in the SharePoint ToolShell study; the Nx, debug and chalk and Shai-Hulud npm compromises in the npm supply-chain study; the AI-orchestrated espionage campaign Anthropic disrupted in the AI threats study; Salt Typhoon, BRICKSTORM and the year's other China-attributed operations in the China-attributed actors study; Static

Tundra and the year's Russian operations in the Russia-attributed actors study; Bybit and the IT-worker schemes in the North Korea-attributed actors study; and the hacktivist attacks on operational technology in the ICS attacks and advisories study. The ransomware groups of the year are traced across seven years in the ransomware ecosystem study; the cloud and SaaS incidents are traced in the series' cloud security incidents study, which had not reached the library when this study was written, so it is named without a link. Everything else in 2025 that the verified record supports is here, in date order, with the source behind each line.

> Evidence grade: the events, attributions, sanctions, charges, directives and laws are **Confirmed** from the government agency, the victim's own statement or SEC filing, the vendor that observed the activity, the CVE, NVD and KEV records, or the MITRE record. Estimates from vendor datasets (Chainalysis on Bybit and on ransomware payments, the Verizon DBIR) and the Snyk write-ups of npm compromises in other maintainers' packages are **Reported** and attributed by name. Checks this study re-ran against the library's ATT&CK, CWE, CAPEC and D3FEND data, and the KEV counts computed from the catalog file, are **Demonstrated** where the computation is this study's own. Where this study draws its own conclusion or maps behavior to ATT&CK on its own reading, it says **Inferred**.

Key facts at a glance

Field	Value
Period	1 January to 31 December 2025, with lead-in exploitation from September and December 2024 and later revisions that describe 2025
The edge-device year	Ivanti Connect Secure zero-days twice (mid-December 2024 to 8 January; mid-March to 3 April), FortiOS CVE-2024-55591 (14 January), Juniper MX routers (UNC3886, March), Citrix NetScaler (June to August), Cisco ASA and Firepower (ArcaneDoor actor, May to September), SonicWall cloud backups (September), F5's BIG-IP source code (August to October), Cisco AsyncOS email gateways (late November to December) [1][28][6][22][2][98][91][79][125]
Three emergency directives	ED 25-02 on Exchange hybrid (7 Aug), ED 25-03 on Cisco ASA and Firepower (25 Sep), ED 26-01 on F5 (15 Oct) [76][98][111]
Servers and applications	SharePoint ToolShell (from 7 Jul), SAP NetWeaver (KEV 29 Apr), Windows CLFS (8 Apr), Oracle E-Business Suite (from 9 Aug), GoAnywhere MFT (from 11 Sep), WSUS (23 Oct) and React Server Components (3 Dec) [63][2][31][80][94][113][123]
SaaS and identity	UNC6040 voice phishing of Salesforce users (from October 2024); UNC6395's stolen Salesloft Drift OAuth tokens (8 to 18 Aug); Commvault Metallic client secrets (May); Scattered Spider's help-desk impersonation (AA23-320A update, 29 Jul) [56][90][78][46][72]
The largest theft	About US$1.5 billion in virtual assets from Bybit on or about 21 February, attributed by the FBI to North Korea (TraderTraitor) [14]
Build-pipeline compromises	tj-actions/changed-files and reviewdog/action-setup (11 to 15 Mar), the Amazon Q Developer extension (Jul), Nx (26 to 27 Aug), the Shai-Hulud worm across more than 500 npm packages (Sep) and its renewed variant (24 Nov) [25][71][84][96][122]
KEV in 2025	245 entries added (186 in 2024), 151 of them with CVE-2025 ids, 31 now flagged for known ransomware use; Microsoft 39, Apple 9, Cisco 8, Fortinet 8; busiest months March (32) and October (31), computed from catalog version 2026.11.10 [2]
Zero-days	Google GTIG counted 90 exploited in the wild in 2025 (78 in 2024), 43 of them (48%) against enterprise software and appliances, the highest share it has recorded [130]
Ransomware	IC3 counted over 3,600 ransomware complaints and losses over US$32 million that exclude downtime and remediation; Akira's proceeds about US$244.17 million as of late September; Medusa over 500 victims (by April 2026); Play about 900 entities (May) [131][120][23][49]
Enforcement	8Base (Phobos) arrests (10 Feb); i-Soon and APT27 charges (5 Mar); Garantex takedown (6 to 7 Mar) and re-designation (14 Aug); Lumma disruption (21 May); Operation Endgame (19 to 22 May); four arrests over the UK retail attacks (10 Jul); Thalha Jubair charged (18 Sep) [11][17][21][77][41][45][62][92]
Policy landmarks	EO 14144 (16 Jan); EO 14306 (6 Jun); UK ransomware payment measures (22 Jul); UN Convention against Cybercrime opened for signature (25 Oct); UK Cyber Security and Resilience Bill introduced (12 Nov) [7][53][70][115][118]
This study's MITRE binding	122 Enterprise technique rows and 3 ATT&CK for ICS rows, 53 group, software and campaign objects with library pages (45 tied directly to a 2025 event), 12 CWE rows with the library's CAPEC pairings, 11 technique-level CAPEC rows, 23 D3FEND countermeasures, and two Navigator layers (Part 15)

Key findings

- **The edge kept falling, and fixes did not end the compromise.** Mandiant found the Ivanti Connect Secure actor tampering with the vendor's Integrity Checker Tool and faking upgrades; CISA's directive on Cisco ASA says the actor altered the device's read-only memory to persist through reboot and upgrade, and its April 2026 update requires a hard power removal because a reboot is not enough; in November CISA said multiple organizations that believed they had patched were not on the minimum fixed versions (Confirmed [1][98][119]).
- **SaaS-to-SaaS trust was the new perimeter.** GTIG says UNC6395 exported data from numerous Salesforce instances with OAuth tokens stolen from the Salesloft Drift app, and that this was not a Salesforce platform flaw; CISA says Commvault's Metallic client secrets may have been taken; Discord's customer-service vendor exposed about 70,000 users' government-ID photos (Confirmed [78][46][105]).
- **Voice was the phishing channel that worked.** UNC6040 talked staff into authorizing a modified Salesforce Data Loader app, including at Google itself; Scattered Spider's 2025 update adds help-desk impersonation to reset passwords and MFA; the FBI warned of AI-generated voices impersonating senior officials (Confirmed [56][72][127]).
- **The build pipeline became an attack surface in its own right.** A compromised GitHub Action used in over 23,000 repositories leaked secrets into public build logs, an over-scoped token let an outsider's code into an AWS extension release, and a worm republished npm packages with each victim's own credentials (Confirmed [24][71][96]).
- **Old bugs still did much of the state work.** AA25-239A says the Salt Typhoon-linked actors used known CVEs, the newest from 2024 and the oldest from 2018, with no zero-days observed; Static Tundra exploited a seven-year-old Cisco Smart Install flaw; 94 of 2025's 245 KEV additions carry pre-2025 CVE ids and 23 carry pre-2020 ids (Confirmed [85][81]; Demonstrated [2]).
- **Crime and state shared the same doors.** Microsoft saw Chinese state actors and the China-based ransomware actor Storm-2603 exploiting SharePoint in the same weeks; Silk Typhoon exploited the same Ivanti zero-day as UNC5221; a Medusa affiliate exploited GoAnywhere (Confirmed [63][19][94]).
- **Disruption hit physical operations.** Lee Enterprises' print distribution, Sensata's shipping and manufacturing, UNFI's food distribution, JLR's retail and production and the shared passenger-processing software airlines rely on were disrupted (Confirmed [10][30][51][88][95]).
- **Governments used every lever.** Three emergency directives, sanctions on Chinese companies, an MSS-affiliated individual, three bulletproof hosts and a crypto exchange, takedowns with private partners, and new binding policy in the US and UK (Confirmed, Part 12).

Top recommendations

1. **Patch edge appliances on the KEV clock, then prove the patch and assume compromise.** ED 25-03 asked for core dumps within a day, CISA later found organizations below the fixed versions, and Mandiant's Ivanti guidance is to run both integrity checks, factory reset on failure, and reset credentials, API keys and certificates (Confirmed [98][119][1]).
2. **Inventory and scope every SaaS integration.** GTIG's Drift guidance is to revoke and rotate integration tokens, scope connected apps to the least they need and restrict them by IP; treat a vendor's client secret as a credential to rotate on any vendor incident (Confirmed [78][46]; Inferred for the client-secret advice).

3. **Make the help desk a security control.** AA23-320A asks for phishing-resistant MFA and monitoring of risky logins, but gives no detailed help-desk verification procedure; organizations must write their own identity check for password and MFA resets (Confirmed [72]; Inferred for the gap).
4. **Pin and scope what your builds trust.** CISA's tj-actions alert asks for auditing affected workflows, rotating exposed secrets and updating the action (Confirmed [25]); its Shai-Hulud alert adds pinning to known-safe releases and phishing-resistant MFA on GitHub and npm (Confirmed [96]); AWS traced its incident to an over-scoped token in a build configuration (Confirmed [71]).
5. **Isolate network-device management and watch configuration.** AA25-239A asks for an out-of-band management plane, default-deny access lists, SNMPv3 with authentication and privacy only, Smart Install and Guest Shell disabled, central immutable logging and firmware integrity checks (Confirmed [85]).
6. **Keep backups out of reach of the identities that run production.** Storm-0501 destroyed data and backups in victims' cloud environments with cloud-native capabilities, and AA23-320A asks for offline, immutable backups (Confirmed [87][72]; Inferred for the generalization).

Scope and method

This study covers intrusions, exploited vulnerabilities, crime, outages and the government response in calendar year 2025. It draws on CISA, FBI, NSA and partner advisories, alerts and directives, the FBI's IC3, the Treasury, the Department of Justice, the White House and its archive, the UK National Crime Agency, NCSC and government, Europol, CERT-EU and UNODC, the victims' own statements and SEC filings (Conduent, Lee Enterprises, Sensata, DaVita, Coinbase, Nucor, UNFI, Erie Indemnity, Aflac, Alaska Air Group, Ingram Micro, F5, RTX, JLR, SonicWall, Red Hat, Discord), the vendors that observed the activity (Mandiant and Google's GTIG, Microsoft, Cisco and Cisco Talos, Fortinet, Fortra, Oracle, Kaspersky, ESET, Volexity, Wiz, StepSecurity, AWS, GitLab, the Nx and React maintainers, Anthropic), the CVE, NVD and KEV records, the live MITRE ATT&CK pages for Salt Typhoon and the ToolShell campaign, and the library's own data files. Every source was opened on 11 November 2026. Quotations are kept to a few words. Tradecraft is described at the level the advisories use, by technique name and id; no exploit details, commands, payload strings or ransom notes are reproduced.

Grade	Meaning
Confirmed	A primary source was opened: the agency, the victim, the vendor that observed the activity, a CVE, NVD or KEV record, or the MITRE record itself
Reported	Known only through a secondary source or a vendor's estimate from its own dataset, attributed by name, such as a Chainalysis figure or a vendor's write-up of another party's compromise
Demonstrated	A reproduction exists: this study re-ran the check against the library's data files or computed the figure from the opened catalog
Inferred	This study's own reasoning from the cited facts, labelled where it appears

How the record is routed:

- **Home studies.** Where another study in this series is the home for an event, this study gives one paragraph and a link: SharePoint ToolShell (the ToolShell study), the npm compromises (the npm supply-chain study), the AI-orchestrated espionage campaign (the AI threats study), Bybit and the IT

workers (the North Korea-attributed actors study) and the hacktivist OT attacks (the ICS attacks and advisories study). The year's ransomware groups are traced across seven years in the ransomware ecosystem study; the series' cloud security incidents study had not reached the library when this study was written, so it is named without a link.

- **Attribution language.** Each source's own words are carried through, because the strength varies: "suspected China-nexus" for UNC5221 (Mandiant), "high confidence" for the Chinese state-sponsored group behind the AI-orchestrated campaign (Anthropic), "moderate confidence" for Storm-2603 as China-based (Microsoft) and for UAT-9686 as China-nexus (Talos), "a nation-state affiliated cyber threat actor" with no state named for F5 (CISA), "an advanced threat actor" with no state named for the Cisco ASA campaign (CISA), and "high confidence" that Static Tundra is Russian state-sponsored (Talos) (Confirmed [1][103][63][125][111][98][81]; Inferred for the comparison). A vendor's name for a cluster (UNC5221, UNC6040, UNC6395, Storm-2603, Storm-1175, Storm-2460, UAT-9686) is used with that vendor's report; its ATT&CK object is given only where the library's data carries the name or a campaign record ties it.
- **Victims who name no actor.** The Conduent, Lee Enterprises, Sensata, DaVita, Nucor, UNFI, Erie, Aflac, Alaska Air Group, Ingram Micro and RTX filings and JLR's statement name no actor (Confirmed [5][10][30][32][40][51][52][55][57][61][95][88]). Press attribution of the insurance and aviation intrusions of June 2025 to Scattered Spider is not in any primary opened for this study, so none is made here.
- **Revised advisories.** AA24-109A (Akira) was updated on 13 November 2025, AA23-320A (Scattered Spider) on 29 July 2025 and AA23-352A (Play) on 4 June 2025; AA25-071A (Medusa) was last updated on 18 August 2026 and its live tables now print ATT&CK v20 ids; ED 25-03 carries an April 2026 update (Confirmed [120][72][49][23][98]). Where a live page mixes later material into a 2025 advisory, this study says so and dates the later material to its own revision.
- **KEV dates and flags.** A KEV date-added value is the day CISA listed the CVE, not the day exploitation began. The known-ransomware flag is revised after listing, so the 31 flags counted here reflect the catalog of November 2026, not what was known in 2025 (Confirmed [2]; Inferred for the caution).
- **ATT&CK versions.** The 2025 advisories print ids from ATT&CK releases before v20 (v17 where the claims record the version). This study maps them to v20.0 through the library's `superseded_by.jsonl`, where T1562.001 becomes T1685 Disable or Modify Tools, T1562.004 becomes T1686 Disable or Modify System Firewall, T1656 becomes T1684.001 Impersonation and T1070.001 becomes T1685.005 Clear Windows Event Logs (Demonstrated [132]).
- **Events before 2025.** The Ivanti Cloud Services Appliance chain (September 2024), the first Ivanti Connect Secure zero-day (mid-December 2024), UNC3886's Juniper backdoors (found mid-2024), UNC6040's vishing (from October 2024), Interlock (from September 2024) and Salt Typhoon's backbone campaign (since at least 2021) began before 2025 but were disclosed or acted on in 2025, and appear on the date of the 2025 record (Confirmed [9][1][22][90][69][85]).
- **What is overstated and what is understated.** This study's own reading of where the 2025 record misleads is set out under Cross-cutting themes, with the evidence for each point.
- **What was not checked.** The following reported events were not opened at a primary source and are left out of the dated record: the attacks on Asahi, Kido nurseries, Kettering Health, Qantas, PowerSchool and Coupang; the Salesforce and Gainsight intrusions of late 2025; Collins Aerospace detail beyond the RTX 8-K; the DOJ's DanaBot and BlackSuit releases (the BlackSuit action is cited only through the IC3 annual

report); the UK GRU sanctions; the UK loan guarantee to JLR; and the body of the Fast Flux advisory. Their absence here is a gap in what was opened, not a judgment on what happened.

Part 1: the year at a glance

One row per dated event or report. Grades and sources are given on each row; later Parts tell the longer stories. The victim's sector is given in brackets where the source names it. "Unnamed" means the verified record names no actor.

Date	Event	Who (as the source names them)	Grade and source
2024-09 (exploitation); 2025-01-22 (release)	AA25-022A: actors chained Ivanti Cloud Service Appliance CVE-2024-8963, CVE-2024-9379, CVE-2024-8190 and CVE-2024-9380 in September 2024 exploitation; the page as opened is dated 31 Jan	Unnamed	Confirmed [9]
2024-12 (mid) to 2025-01-08	Zero-day exploitation of Ivanti Connect Secure CVE-2025-0282; Ivanti discloses CVE-2025-0282 and CVE-2025-0283 on 8 Jan; KEV lists CVE-2025-0282 the same day, now with known ransomware use [cross-sector VPN edge]	UNC5221, suspected China-nexus (Mandiant; UNC5337 merged into it); Microsoft says Silk Typhoon also exploited it as a zero-day in January	Confirmed [1][2][19]
2025-01-03	OFAC designates Integrity Technology Group of Beijing for support to Flax Typhoon, which Treasury calls a Chinese state-sponsored cyber group active against US and European entities from summer 2022 to fall 2023	Flax Typhoon	Confirmed [3][4]
2025-01-13	Conduent operational disruption; a threat actor accessed part of its environment and exfiltrated files with a significant number of individuals' personal information; 8-K Item 1.05 filed 14 Apr [business and government services]	Unnamed	Confirmed [5]
2025-01-14	Fortinet FG-IR-24-535: FortiOS and FortiProxy authentication bypass CVE-2024-55591 exploited in the wild; KEV the same day, with known ransomware use [cross-sector firewall edge]	Unnamed	Confirmed [6][2]
2025-01-16	Executive Order 14144 on strengthening and promoting innovation in the nation's cybersecurity, including machine-readable secure software development attestations	The White House	Confirmed [7]
2025-01-17	Treasury sanctions Sichuan Juxinhe Network Technology for direct involvement in Salt Typhoon and MSS-affiliated Yin Kecheng over the compromise of Treasury's Departmental Offices network [telecom; government]	Salt Typhoon; an MSS-affiliated individual	Confirmed [4]

Date	Event	Who (as the source names them)	Grade and source
2025-01-29	Wiz finds a publicly accessible, unauthenticated DeepSeek ClickHouse database exposing over a million log lines, including chat history and secret keys [AI and technology]	An exposure; no actor	Confirmed [8]
2025-02-03	Lee Enterprises: network accessed, critical applications encrypted and files exfiltrated; print distribution, billing and collections disrupted; 8-K Item 1.05 of 18 Feb [media]	Unnamed	Confirmed [10]
2025-02-05	Chainalysis estimates 2024 ransomware payments at about US$813.55 million, down 35% from 2023	Chainalysis	Reported [16]
2025-02-10	DOJ unseals charges against Roman Berezhnoy and Egor Glebov over Phobos affiliate activity under the 8Base name: over 1,000 victims and over US$16 million in ransoms; the 8Base site seized and over 100 servers disrupted	8Base (Phobos affiliates)	Confirmed [11]
2025-02-11	The US, Australia and the UK sanction Zservers bulletproof hosting for supporting LockBit	Zservers; LockBit	Confirmed [12]
2025-02-19	AA25-050A #StopRansomware: Ghost (Cring)	Ghost (Cring)	Confirmed [13]
2025-02-21	About US$1.5 billion in virtual assets stolen from Bybit; FBI PSA 26 Feb; Chainalysis counts about 401,000 ETH taken during a routine cold-to-hot wallet transfer [crypto exchange]	North Korea (TraderTraitor, per the FBI)	Confirmed [14]; Reported [15]
2025-03-05	DOJ charges 12 Chinese contract hackers and law enforcement officers, including eight i-Soon employees, two MPS officers and APT27 actors Yin Kecheng and Zhou Shuai, and seizes i-Soon's primary domain; Treasury sanctions Zhou Shuai and Shanghai Heiying; Microsoft reports Silk Typhoon's shift to the IT supply chain	i-Soon; APT27; Silk Typhoon	Confirmed [17][18][19]
2025-03-06	CISA relays an FBI warning of a data-extortion scam targeting corporate executives (title and date only checked); Garantex domain seizures executed with Germany and Finland, announced 7 Mar	FBI; Garantex	Confirmed [20][21]
2025-03-11	Mandiant: UNC3886 deployed TINYSHELL-based backdoors on end-of-life Juniper MX routers, found mid-2024; Juniper assigns CVE-2025-21590 for the veriexec bypass [network infrastructure]	UNC3886 (China-nexus espionage)	Confirmed [22]

Date	Event	Who (as the source names them)	Grade and source
2025-03-11 to 03-15	reviewdog/action-setup@v1 compromised on 11 Mar (CVE-2025-30154), the likely enabler of the tj-actions/changed-files compromise (CVE-2025-30066, affected window 12 to 15 Mar UTC); StepSecurity detects it on 14 Mar; secrets leak into public build logs; KEV adds 18 and 24 Mar [software and CI]	Unnamed	Confirmed [24][25][26]
2025-03-12	AA25-071A #StopRansomware: Medusa (TTPs as of February 2025)	Medusa	Confirmed [23]
2025-03 (mid)	Operation ForumTroll: personalized phishing links infect Russian organizations through a Chrome sandbox-escape zero-day, CVE-2025-2783; Kaspersky reports 25 Mar; KEV 27 Mar [Russian organizations]	Unnamed	Confirmed [27][2]
2025-03 (mid) to 04-03	Ivanti Connect Secure CVE-2025-22457, disclosed 3 Apr, exploited since mid-March with TRAILBLAZE, BRUSHFIRE and SPAWN malware; KEV 4 Apr [cross-sector VPN edge]	UNC5221, suspected China-nexus (Mandiant)	Confirmed [28]
2025-03-18	FortiOS CVE-2025-24472 added to KEV, with known ransomware use	Unnamed	Confirmed [2]
2025-04	Cyber attacks on M&S, Co-op and Harrods (arrests on 10 Jul) [retail]	Unnamed in the opened record	Confirmed [62]
2025-04-01	Apache Tomcat CVE-2025-24813 (CWE-44, CWE-502, CWE-706) added to KEV	Unnamed	Confirmed [114][2]
2025-04-03	AA25-093A, "Fast Flux: A National Security Threat", from NSA, CISA, FBI and partners (title and date only checked)	NSA, CISA, FBI	Confirmed [29]
2025-04-06	Sensata ransomware incident encrypts devices, disrupts shipping, receiving and manufacturing; files taken (8-K Item 1.05) [manufacturing]	Unnamed	Confirmed [30]
2025-04-07	CrushFTP CVE-2025-31161 added to KEV, with known ransomware use	Unnamed	Confirmed [2]
2025-04-08	Microsoft: zero-day CLFS elevation of privilege CVE-2025-29824 exploited post-compromise via PipeMagic, leading to ransomware, against targets in US IT and real estate, Venezuelan finance, a Spanish software company and Saudi retail; KEV the same day	Storm-2460	Confirmed [31][2]
2025-04-12	DaVita becomes aware of ransomware that encrypted parts of its network (8-K) [healthcare, dialysis]	Unnamed	Confirmed [32]

Date	Event	Who (as the source names them)	Grade and source
2025-04-16	CISA guidance on credential risks from potential unauthorized access to a legacy Oracle cloud environment; scope and impact unconfirmed	Unnamed	Confirmed [33]
2025-04-22	Volexity reports Russian threat actors phishing Microsoft 365 OAuth authorization codes (title and date checked)	Russian threat actors (Volexity)	Confirmed [34]
2025-04-23	Verizon's 2025 DBIR: third-party involvement in 30% of breaches, exploitation 20% of initial access, ransomware in 44% of breaches	Verizon	Reported [36]
2025-04-29	SAP NetWeaver CVE-2025-31324 (CWE-434) added to KEV, with known ransomware use; GTIG's review of 2024 counts 75 zero-days (later revised to 78)	Unnamed; GTIG	Confirmed [2][114][35]
2025-05-06	CISA warns that unsophisticated actors are targeting ICS and SCADA in US oil and natural gas, energy and transportation; CISA, FBI, EPA and DOE publish primary mitigations for OT [energy; transportation]	Unsophisticated cyber actors	Confirmed [37][38]
2025-05-11	Coinbase receives an extortion email; the actor obtained customer and internal data by paying overseas support contractors or employees; Coinbase does not pay and estimates US$180 million to US$400 million in costs (8-K Item 1.05) [crypto exchange]	Unnamed	Confirmed [39]
2025-05-13	Nucor identifies unauthorized third-party access to certain IT systems and takes systems offline (8-K Item 1.05) [steel manufacturing]	Unnamed	Confirmed [40]
2025-05-15	SAP CVE-2025-42999 added to KEV, with known ransomware use; the FBI's first PSA on impersonation of senior US officials (dated through its 19 Dec update)	Unnamed	Confirmed [2][127]
2025-05-19 to 05-22	Operation Endgame's second phase: about 300 servers taken down, 650 domains neutralised, 20 arrest warrants and EUR 3.5 million seized, against Bumblebee, Latrodectus, Qakbot, HijackLoader, DanaBot, Trickbot and Warmcookie	Malware operators	Confirmed [45]
2025-05-21	Lumma disrupted: Microsoft's civil action on about 2,300 domains and DOJ seizure of five domains and the central command structure; over 394,000 infected Windows computers identified 16 Mar to 16 May; AA25-141B on LummaC2 the same day	Lumma Stealer operators	Confirmed [41][42][43]

Date	Event	Who (as the source names them)	Grade and source
2025-05-21	AA25-141A: GRU 85th GTsSS unit 26165 targets Western logistics and technology companies involved in aid to Ukraine, and IP cameras at Ukrainian border crossings [logistics; IT]	APT28 (GRU unit 26165)	Confirmed [44]
2025-05-22	CISA: actors may have accessed client secrets for Commvault's Metallic M365 backup SaaS in Azure, possibly part of a wider campaign against SaaS applications; CVE-2025-3928 in KEV [backup SaaS]	Unnamed	Confirmed [46]
2025-05-29	OFAC sanctions Funnull Technology for hosting the infrastructure behind pig-butchering scams with over US$200 million in US victim-reported losses	Funnull	Confirmed [47]
2025-06	One of Google's corporate Salesforce instances, holding small-business contact data, hit by UNC6040 voice-phishing data theft (per GTIG's 5 Aug update to its 4 Jun report) [technology]	UNC6040; extortion by UNC6240, which claims to be ShinyHunters	Confirmed [56]
2025-06	Akira payloads encrypt Nutanix AHV disks in a June incident, likely after SonicWall CVE-2024-40766 abuse (AA24-109A update, 13 Nov)	Akira	Confirmed [120]
2025-06-04	Updated Play advisory: about 900 affected entities as of May 2025; SimpleHelp CVE-2024-57727 exploited for access; ESXi variant	Play	Confirmed [48][49]
2025-06-05	Cisco Talos: PathWiper destructive attack on a Ukrainian critical infrastructure entity, pushed through a legitimate endpoint administration framework [critical infrastructure]	Russia-nexus APT (high confidence)	Confirmed [50]
2025-06-05	UNFI becomes aware of unauthorized activity; systems taken offline impair order fulfilment and distribution (8-K Item 1.05 of 26 Jun) [food distribution]	Unnamed	Confirmed [51]
2025-06-06	Executive Order 14306 amends EO 13694 and EO 14144	The White House	Confirmed [53]
2025-06-07	Erie Indemnity identifies unusual network activity, determined to be an information security event (8-K) [insurance]	Unnamed	Confirmed [52]
2025-06-09	Erlang/OTP SSH CVE-2025-32433 (CWE-306) added to KEV	Unnamed	Confirmed [2]

Date	Event	Who (as the source names them)	Grade and source
2025-06-12	AA25-163A: ransomware actors exploit unpatched SimpleHelp RMM to compromise customers of a utility billing software provider [utilities]	Ransomware actors	Confirmed [54]
2025-06-12	Aflac identifies unauthorized network access, contained within hours, not ransomware (8-K of 20 Jun) [insurance]	Unnamed	Confirmed [55]
2025-06-23	Hawaiian Airlines identifies an incident affecting certain IT systems; flights operate as scheduled (Alaska Air Group 8-K) [aviation]	Unnamed	Confirmed [57]
2025-06-30	CISA, FBI, DC3 and NSA fact sheet: Iranian state-sponsored or affiliated actors may target US networks; DOJ coordinated actions against North Korean remote IT worker schemes; Citrix CVE-2025-6543 in KEV	Iran; North Korea	Confirmed [58][59][2]
2025-07-01	OFAC sanctions Aeza Group bulletproof hosting	Aeza Group	Confirmed [60]
2025-07-03	Xu Zewei arrested in Milan (DOJ release 8 Jul) over alleged hacking for the MSS Shanghai State Security Bureau, including COVID-19 research intrusions and the 2021 HAFNIUM Exchange campaign	Shanghai Powerock Network employee	Confirmed [67]
2025-07-05	Ingram Micro identifies ransomware on certain internal systems and takes systems offline (8-K) [IT distribution]	Unnamed	Confirmed [61]
2025-07-07 to 07-23	SharePoint ToolShell: exploitation attempts from 7 Jul; MSRC guidance on CVE-2025-53770 on 19 Jul; KEV 20 and 22 Jul; Warlock ransomware deployed from 18 Jul; Microsoft's report 22 Jul, updated 23 Jul [finance; education; energy; healthcare, per the C0058 record]	Linen Typhoon and Violet Typhoon (Chinese state); Storm-2603 (China-based, moderate confidence)	Confirmed [63][64][65][66]
2025-07-10	UK NCA arrests four people, aged 17 to 20, over the attacks on M&S, Co-op and Harrods; Citrix NetScaler CVE-2025-5777 in KEV, with known ransomware use; Oracle EBS suspicious activity begins (per GTIG)	Unnamed; unnamed; unnamed	Confirmed [62][2][80]
2025-07-18	ESET discovers the WinRAR zero-day CVE-2025-8088 exploited in the wild (published 11 Aug; KEV 12 Aug)	RomCom (Russia-aligned, per ESET)	Confirmed [68]
2025-07-22	AA25-203A #StopRansomware: Interlock, active since September 2024 against businesses and critical infrastructure in North America and Europe; UK announces it will go ahead with ransomware payment measures	Interlock; UK Home Office	Confirmed [69][70]

Date	Event	Who (as the source names them)	Grade and source
2025-07-23	AWS-2025-015: Amazon Q Developer for VS Code extension v1.84 (CVE-2025-8217) carried an outsider's code, committed with an over-scoped token from the build configuration [developer tools]	Unnamed	Confirmed [71]
2025-07-29	AA23-320A Scattered Spider updated with new social-engineering TTPs, DragonForce ransomware against ESXi and Snowflake data theft	Scattered Spider	Confirmed [72]
2025-07-31	Microsoft: Secret Blizzard uses ISP-level adversary-in-the-middle in Moscow to deliver ApolloShadow to foreign embassies; AA25-212A on a CISA and USCG hunt at a US critical infrastructure organization [diplomatic; critical infrastructure]	Secret Blizzard (FSB Center 16, per CISA as Microsoft notes); unnamed	Confirmed [73][74]
2025-08	Anthropic's August threat report: a data-extortion operation scaled with Claude Code and North Korean IT-worker fraud using AI (headlines only checked)	Unnamed; North Korea	Confirmed [75]
2025-08-07	Emergency Directive 25-02: Exchange hybrid CVE-2025-53786, agency actions due 11 Aug	CISA	Confirmed [76]
2025-08-08 to 08-18	UNC6395 exports data from numerous Salesforce instances using compromised Salesloft Drift OAuth tokens and reads email in a few Drift-integrated Google Workspace accounts on 9 Aug; tokens revoked 20 Aug; GTIG report 26 Aug [cross-sector SaaS]	UNC6395	Confirmed [78]
2025-08-09	F5 learns that a highly sophisticated nation-state actor held long-term access to its BIG-IP development environment; Oracle EBS exploited as a zero-day as early as this day (GTIG) [technology vendor; cross-sector]	Nation-state actor (no state named); Cl0p-branded actor	Confirmed [79][80]
2025-08-11	DOJ coordinated disruption of BlackSuit (Royal) ransomware, per the IC3 2025 report (DOJ release not opened)	BlackSuit (Royal)	Confirmed [131]
2025-08-14	OFAC re-designates Garantex and designates its successor Grinex, three executives and six companies	Garantex; Grinex	Confirmed [77]
2025-08-20	FBI PSA and Cisco Talos: FSB Center 16 actors (Static Tundra) exploit Cisco Smart Install CVE-2018-0171 and SNMP on end-of-life devices, collecting configurations from thousands of US critical infrastructure devices [telecom; higher education; manufacturing]	Static Tundra; FBI relates it to Berserk Bear and Dragonfly	Confirmed [82][81]

Date	Event	Who (as the source names them)	Grade and source
2025-08-26	Citrix CVE-2025-7775 added to KEV	Unnamed	Confirmed [2]
2025-08-26 to 08-27	Eight malicious Nx releases live on npm for about 5h20m, abusing AI coding CLIs; stolen credentials posted to repositories named s1ngularity-repository [software]	Unnamed	Confirmed [84]; Reported [83]
2025-08-27	AA25-239A: PRC state-sponsored actors overlapping Salt Typhoon compromise telecom backbone routers and other networks worldwide; Microsoft reports Storm-0501's cloud-based ransomware	Salt Typhoon, OPERATOR PANDA, RedMike, UNC5807, GhostEmperor; Storm-0501	Confirmed [85][87]
2025-09-02	JLR shuts down systems after a cyber incident; retail and production severely disrupted [automotive manufacturing]	Unnamed	Confirmed [88]
2025-09-08	An npm maintainer is phished from a lookalike support domain; malicious versions of debug, chalk and other popular packages published [software]	Unnamed	Reported [89]
2025-09-11	Storm-1175 activity against GoAnywhere MFT begins (per Microsoft, 6 Oct)	Storm-1175, a Medusa affiliate	Confirmed [94]
2025-09-12	FBI FLASH-20250912-001 on UNC6040 and UNC6395; DOJ approves F5's disclosure delay	UNC6040; UNC6395	Confirmed [90][79]
2025-09 (mid)	Anthropic detects a Chinese state-sponsored group manipulating Claude Code against about thirty targets, succeeding in a small number; disclosed 13 Nov [technology; finance; chemical manufacturing; government]	Chinese state-sponsored group (high confidence)	Confirmed [103]
2025-09 (to 09-23)	The self-replicating Shai-Hulud worm compromises over 500 npm packages; CISA's alert of 23 Sep advises pinning to releases before 16 Sep [software]	Unnamed	Confirmed [96]
2025-09-17	SonicWall discloses access to MySonicWall cloud backup files (initially under 5% of firewalls; 28 Oct: all customers who used the service) [security vendor]	Unnamed	Confirmed [91]
2025-09-18	DOJ unseals a complaint against UK national Thalha Jubair: about 120 intrusions from May 2022 to September 2025, at least 47 US victims, over US$115 million in ransom paid; Fortra advisory FI-2025-012 on GoAnywhere CVE-2025-10035	Scattered Spider; unnamed	Confirmed [92][93]

Date	Event	Who (as the source names them)	Grade and source
2025-09-19	RTX becomes aware of ransomware on systems supporting Collins' MUSE shared passenger-processing software; airlines move to manual processes (8-K) [aviation]	Unnamed	Confirmed [95]
2025-09-23	AA25-266A: a federal civilian agency compromised through GeoServer CVE-2024-36401, exploited 11 days after disclosure and about three weeks before EDR alerts [government]	Unnamed	Confirmed [97]
2025-09-25	Emergency Directive 25-03 on Cisco ASA and Firepower CVE-2025-20333 and CVE-2025-20362; Cisco advisory and event response; Talos ties the activity to the ArcaneDoor actor; NCSC names RayInitiator and LINE VIPER; KEV the same day	ArcaneDoor actor (UAT4356, STORM-1849); no state named by CISA	Confirmed [98][99][100][101][102]
2025-09-29	Cl0p-branded extortion emails to executives alleging Oracle EBS data theft; GoAnywhere CVE-2025-10035 in KEV, with known ransomware use	Cl0p-branded actor; unnamed	Confirmed [80][2]
2025-10-02	Red Hat: an unauthorized third party copied data from a GitLab instance used by Red Hat Consulting [technology]	Unnamed	Confirmed [104]
2025-10-03	Discord: its customer-service vendor 5CA compromised; about 70,000 users may have had government-ID photos exposed; the actor sought a ransom [technology]	Unnamed	Confirmed [105]
2025-10-04 to 10-06	Oracle Security Alert for CVE-2025-61882 (Rev 1, 4 Oct; Rev 2, 6 Oct); CVE published 5 Oct; KEV 6 Oct	Oracle	Confirmed [106][107][108]
2025-10-11	Oracle patches CVE-2025-61884; KEV 20 Oct, with known ransomware use	Oracle	Confirmed [80][2]
2025-10-14	NCSC Annual Review 2025: 204 nationally significant incidents in the year to August, against 89 the year before	UK NCSC	Confirmed [109][110]
2025-10-15	F5 files its 8-K; Emergency Directive 26-01 on F5 devices	F5; CISA	Confirmed [79][111]
2025-10-22	F5's CISO apologizes and reports no evidence of supply-chain modification, validated by NCC Group and IOActive	F5	Confirmed [112]
2025-10-23	Microsoft out-of-band fix for WSUS CVE-2025-59287 (CVSS 9.8); CERT-EU advisory and KEV listing 24 Oct; proof of concept public	Unnamed	Confirmed [113][114]

Date	Event	Who (as the source names them)	Grade and source
2025-10-25	The UN Convention against Cybercrime opens for signature in Hanoi	UN	Confirmed [115]
2025-11-05	GTIG identifies PROMPTFLUX and PROMPTSTEAL, malware that uses LLMs during execution; Cisco reports a DoS variant against unpatched ASA devices	Unnamed; ArcaneDoor actor	Confirmed [116][99]
2025-11-10 to 11-14	Operation Endgame's November phase: over 1,025 servers taken down or disrupted, 20 domains seized, 11 locations searched, against Rhadamanthys, VenomRAT and the Elysium botnet; the main VenomRAT suspect arrested in Greece on 3 Nov; Europol release 13 Nov	Malware operators	Confirmed [117]
2025-11-12	CISA: organizations believed they had patched Cisco ASA and Firepower but were below the minimum fixed versions; UK Cyber Security and Resilience Bill introduced	CISA; UK government	Confirmed [119][118]
2025-11-13	AA24-109A Akira updated; Anthropic discloses the AI-orchestrated espionage campaign	Akira; Chinese state-sponsored group	Confirmed [120][103]
2025-11-14 and 11-18	Fortinet FortiWeb CVE-2025-64446 (path traversal) and CVE-2025-58034 added to KEV	Unnamed	Confirmed [2]
2025-11-19	The US, Australia and the UK sanction Media Land bulletproof hosting for supporting ransomware	Media Land	Confirmed [121]
2025-11-24	GitLab identifies a renewed, large-scale Shai-Hulud variant with a destructive fallback	Unnamed	Confirmed [122]
2025-11-29 to 12-05	React Server Components CVE-2025-55182 (CVSS 10.0, unauthenticated remote code execution) reported 29 Nov, disclosed 3 Dec, in KEV 5 Dec with known ransomware use [web applications]	Unnamed	Confirmed [123][2]
2025-11 (late) to 12-17	UAT-9686 targets Cisco AsyncOS Secure Email Gateway and Email and Web Manager with the AquaShell backdoor; Cisco aware 10 Dec; KEV CVE-2025-20393 on 17 Dec	UAT-9686 (China-nexus, moderate confidence)	Confirmed [125]
2025-12-04	CISA, NSA and the Canadian Cyber Centre malware analysis report on BRICKSTORM (second report 19 Dec)	PRC state-sponsored actors	Confirmed [124]

Date	Event	Who (as the source names them)	Grade and source
2025-12-18	AA25-343A last revised: pro-Russia hacktivists reach OT through minimally secured internet-facing VNC, with impacts including physical damage (initial release date not checked) [water; food and agriculture; energy]	CARR, Z-Pentest, NoName057(16), Sector16	Confirmed [126]
2025-12-19	FBI PSA update: ongoing impersonation of senior US officials by smishing and vishing that may use AI-generated voices	Unnamed	Confirmed [127]

Part 2: the edge-device year

Ivanti Connect Secure, twice. Mandiant identified zero-day exploitation of Ivanti Connect Secure CVE-2025-0282 beginning in mid-December 2024; Ivanti disclosed it with CVE-2025-0283 on 8 January, and KEV listed CVE-2025-0282 the same day; the entry now carries the known-ransomware flag (Confirmed [1][2]). Mandiant's update of 17 January attributes the activity to UNC5221, a "suspected China-nexus espionage actor", with UNC5337 merged into it, and names the SPAWN malware family, DRYHOOK and PHASEJAM (Confirmed [1]). ATT&CK carries S9013 DRYHOOK and S9014 PHASEJAM, and S9024 SPAWNCHIMERA combines capabilities from the SPAWN family (Demonstrated [134]). Mandiant says the actor tampered with the Integrity Checker Tool's manifest and faked upgrades, and its guidance is to run the internal and external integrity checks, factory reset on any failure, reset credentials and API keys, revoke certificates and keep logs off the device (Confirmed [1]). NVD lists CWE-121 and CWE-787 for CVE-2025-0282 (Confirmed [128]). Microsoft separately says Silk Typhoon exploited CVE-2025-0282 as a zero-day in January (Confirmed [19]). In April came a second flaw: Mandiant reports that CVE-2025-22457, disclosed on 3 April, was exploited from mid-March to deploy the TRAILBLAZE in-memory dropper and the BRUSHFIRE passive backdoor alongside SPAWN, again by UNC5221; KEV listed it on 4 April (Confirmed [28]). ATT&CK carries S9012 TRAILBLAZE and S9011 BRUSHFIRE (Demonstrated [134]). AA25-022A, dated 31 January on the page opened, also describes four chained Ivanti Cloud Service Appliance CVEs exploited in September 2024 (Confirmed [9]).

Fortinet. Fortinet's FG-IR-24-535, revised 14 January, states that the FortiOS and FortiProxy authentication bypass CVE-2024-55591 was exploited in the wild; KEV listed it the same day, and FortiOS CVE-2025-24472 on 18 March; both carry the known-ransomware flag (Confirmed [6][2]). FortiWeb's path traversal CVE-2025-64446 entered KEV on 14 November and FortiWeb CVE-2025-58034 on 18 November (Confirmed [2]).

Juniper routers and UNC3886. On 11 March Mandiant reported that UNC3886 (G1048), a China-nexus espionage group, had deployed TINYSHELL-based backdoors on end-of-life Juniper MX routers, a finding from mid-2024; Juniper assigned CVE-2025-21590 for the veriexec bypass (Confirmed [22]). ATT&CK records the activity as campaign C0056 RedPenguin, July 2024 to March 2025 (Demonstrated [134]).

Citrix NetScaler. NetScaler ADC and Gateway CVE-2025-6543 entered KEV on 30 June, CVE-2025-5777 (an out-of-bounds read; NVD CWE-125 and CWE-908) on 10 July with the known-ransomware flag, and CVE-2025-7775 on 26 August (Confirmed [2][128]).

Cisco ASA and Firepower, and the ArcaneDoor actor. Emergency Directive 25-03 of 25 September told federal agencies to identify and mitigate compromise of Cisco ASA and Firepower devices through CVE-2025-20333 and CVE-2025-20362, with core dumps due on 26 September; it says the actor manipulated the ASA's read-only memory to persist through reboot and upgrade, and its April 2026 update requires a hard power removal because a reboot is not sufficient (Confirmed [98]). CISA names "an advanced threat actor" and no state; Cisco says it was engaged in May 2025 and links the activity to the ArcaneDoor actor (Confirmed [98]). Cisco's advisory, first published the same day, rates CVE-2025-20333 at CVSS 9.9 (CWE-120) and says it was aware of attempted exploitation; NVD gives CWE-862 for CVE-2025-20362; KEV listed both on 25 September (Confirmed [100][128][2]). Talos's update ties the new activity, including CVE-2025-20363, with high confidence to UAT4356, which Microsoft tracks as STORM-1849 (Confirmed [101]). The UK NCSC names the malware RayInitiator and LINE VIPER (Confirmed [102]). Cisco's event response says the actor has a FXOS persistence mechanism that survives upgrades, and its update of 5 November reports a denial-of-service variant against unpatched devices (Confirmed [99]). On 12 November CISA said that multiple organizations believed they had patched but were not on the minimum fixed versions (Confirmed [119]). ATT&CK's C0046 ArcaneDoor spans July 2023 to April 2024 only, so the 2025 wave falls outside the campaign record's window; the 2024 tools are S1186 Line Dancer and S1188 Line Runner, and no ATT&CK object carries RayInitiator or LINE VIPER (Demonstrated [134][101]).

SonicWall's cloud backups. On 17 September SonicWall disclosed that MySonicWall cloud backup files had been accessed, initially saying fewer than 5% of firewalls were affected; its update of 28 October, after a Mandiant investigation, confirmed access to the backup files of all customers who used the cloud backup service (Confirmed [91]). AA24-109A's 2025 update separately says Akira likely abused SonicWall CVE-2024-40766 in a June incident (Confirmed [120]).

F5. F5's 8-K, filed on 15 October, says it learned on 9 August that a highly sophisticated nation-state actor had long-term, persistent access to its BIG-IP product development environment and engineering knowledge platform and exfiltrated portions of BIG-IP source code and undisclosed vulnerability information; the DOJ approved a delay of disclosure on 12 September (Confirmed [79]). Emergency Directive 26-01 of 15 October calls the actor "nation-state affiliated", names no state, and told agencies to update F5OS, BIG-IP TMOS, BIG-IQ and BNK/CNF by 22 October and other F5 devices by 31 October, to report inventories, and to disconnect public-facing devices past end of support (Confirmed [111]). On 22 October F5's CISO apologized and wrote that F5 had no knowledge of undisclosed critical or remote code execution vulnerabilities and no evidence of modification to its software supply chain, a finding validated by NCC Group and IOActive (Confirmed [112]).

Cisco AsyncOS and UAT-9686. Talos reported on 17 December that UAT-9686, a China-nexus actor in its moderate-confidence assessment, targets Cisco AsyncOS Secure Email Gateway and Email and Web Manager and deploys the AquaShell backdoor; activity dates from at least late November, Cisco became aware on 10 December, and KEV listed CVE-2025-20393 on 17 December (Confirmed [125]).

Static Tundra and the old Cisco bug. The FBI's PSA of 20 August says actors attributed to FSB Center 16 exploited Cisco Smart Install CVE-2018-0171 and SNMP on end-of-life devices, collected configuration files from thousands of networking devices in US critical infrastructure, and showed interest in industrial protocols (Confirmed [82]). The Russia Part tells the attribution.

The exploitation numbers. Computed from the KEV catalog (version 2026.11.10, 1,779 entries), 245 entries were added in 2025, against 186 in 2024; 151 carry CVE-2025 ids, 94 carry older ids and 23 carry pre-2020

ids; 31 are flagged today for known ransomware use; the vendors with the most additions were Microsoft (39), Apple (9), Cisco (8), Fortinet (8), Google (7), Linux (7) and Ivanti (7); the busiest months were March (32) and October (31); and the most common CWEs were CWE-78 (18), CWE-502 (15), CWE-22 (13), CWE-787 (11) and CWE-416 (11) (Confirmed [2]; Demonstrated for the computation). NVD's API returns 49,972 CVE records with a 2025 published date, including records later rejected (Confirmed [129]). Google GTIG counted 90 zero-days exploited in the wild in 2025, against 78 in 2024 and 100 in 2023; 43 of them (48%) targeted enterprise software and appliances, the highest share on its record (Confirmed [130]). Its review of 2024, published on 29 April, had counted 75, later revised to 78, with over 60% of enterprise zero-days in security and networking products (Confirmed [35]). The year's headline additions, in date order:

CVE	Product	What the record says	KEV added	Source
CVE-2025-0282	Ivanti Connect Secure	Stack-based overflow (CWE-121, CWE-787); zero-day from mid-December 2024; known ransomware use	2025-01-08	Confirmed [1][128][2]
CVE-2024-55591	FortiOS, FortiProxy	Authentication bypass, exploited in the wild; known ransomware use	2025-01-14	Confirmed [6][2]
CVE-2025-30066, CVE-2025-30154	tj-actions/changed-files, reviewdog/action-setup	Embedded malicious code (CWE-506)	2025-03-18, 2025-03-24	Confirmed [25][26]
CVE-2025-24472	FortiOS, FortiProxy	Known ransomware use	2025-03-18	Confirmed [2]
CVE-2025-2783	Google Chrome	Sandbox escape, Operation ForumTroll	2025-03-27	Confirmed [27]
CVE-2025-24813	Apache Tomcat	CWE-44, CWE-502, CWE-706	2025-04-01	Confirmed [114]
CVE-2025-22457	Ivanti Connect Secure	Exploited from mid-March by UNC5221	2025-04-04	Confirmed [28]
CVE-2025-31161	CrushFTP	Known ransomware use	2025-04-07	Confirmed [2]
CVE-2025-29824	Windows CLFS	Zero-day elevation of privilege; known ransomware use	2025-04-08	Confirmed [31][2]
CVE-2025-31324	SAP NetWeaver	Unrestricted file upload (CWE-434); known ransomware use	2025-04-29	Confirmed [2][114]
CVE-2025-42999	SAP NetWeaver	Known ransomware use	2025-05-15	Confirmed [2]
CVE-2025-3928	Commvault	Listed with the Metallic alert	By 2025-05-22	Confirmed [46]
CVE-2025-32433	Erlang/OTP SSH	Missing authentication (CWE-306)	2025-06-09	Confirmed [2]
CVE-2025-6543, CVE-2025-5777, CVE-2025-7775	Citrix NetScaler ADC and Gateway	CVE-2025-5777 is an out-of-bounds read (CWE-125, CWE-908) with known ransomware use	2025-06-30, 2025-07-10, 2025-08-26	Confirmed [2][128]
CVE-2025-53770, CVE-2025-49704, CVE-2025-49706	SharePoint Server (on premises)	Deserialization (CWE-502), code injection (CWE-94), improper authentication (CWE-287); known ransomware use	2025-07-20, 2025-07-22	Confirmed [64][65][2]
CVE-2025-8088	WinRAR	Zero-day used by RomCom	2025-08-12	Confirmed [68]

CVE	Product	What the record says	KEV added	Source
CVE-2025-20333, CVE-2025-20362	Cisco ASA and FTD	Buffer copy without size check (CWE-120), missing authorization (CWE-862)	2025-09-25	Confirmed [100][128][98]
CVE-2025-10035	Fortra GoAnywhere MFT	Deserialization in the License Servlet (CWE-502, CWE-77); known ransomware use	2025-09-29	Confirmed [93][114][2]
CVE-2025-61882, CVE-2025-61884	Oracle E-Business Suite	Unauthenticated remote code execution, CVSS 9.8 (CWE-287); both known ransomware use	2025-10-06, 2025-10-20	Confirmed [106][108][2]
CVE-2025-59287	Windows Server Update Services	Deserialization (CWE-502), CVSS 9.8	2025-10-24	Confirmed [113][114]
CVE-2025-64446, CVE-2025-58034	Fortinet FortiWeb	Path traversal (CVE-2025-64446)	2025-11-14, 2025-11-18	Confirmed [2]
CVE-2025-55182	React Server Components	Unauthenticated remote code execution, CVSS 10.0; known ransomware use	2025-12-05	Confirmed [123][2]
CVE-2025-20393	Cisco AsyncOS	Exploited by UAT-9686	2025-12-17	Confirmed [125]

Two widely discussed 2025 flaws are absent from KEV as of catalog 2026.11.10: Exchange hybrid CVE-2025-53786, the subject of ED 25-02, and SharePoint CVE-2025-53771, which has no KEV date in its NVD record (Confirmed [76][65]).

Part 3: the server and application year

SharePoint ToolShell, in one paragraph. The home for ToolShell in this series is the SharePoint ToolShell study. Microsoft says exploitation attempts against on-premises SharePoint began as early as 7 July, by Linen Typhoon and Violet Typhoon, "two named Chinese nation-state actors", and by Storm-2603, which it assesses with moderate confidence to be China-based and which deployed Warlock ransomware through Group Policy from 18 July (Confirmed [63]). MSRC published guidance for CVE-2025-53770 and CVE-2025-53771 on 19 July for on-premises SharePoint only; KEV listed CVE-2025-53770 on 20 July and CVE-2025-49704 and CVE-2025-49706 on 22 July, all with the known-ransomware flag (Confirmed [64][2]). NVD lists CWE-502 for CVE-2025-53770, CWE-94 for CVE-2025-49704 and CWE-287 for CVE-2025-49706 and CVE-2025-53771 (Confirmed [65]). Microsoft's mitigations are AMSI in Full Mode, Defender antivirus, rotation of ASP.NET machine keys and an IIS restart (Confirmed [63]). ATT&CK records the wave as C0058 SharePoint ToolShell Exploitation, created 15 October 2025, with 35 technique entries, the groups G0027 Threat Group-3390 and G0128 ZIRCONIUM, which carry the aliases Linen Typhoon and Violet Typhoon in the library, and the software S0357 Impacket, S0002 Mimikatz, S0508 ngrok and S0029 PsExec (Confirmed [66]; Demonstrated [134]).

SAP NetWeaver. KEV listed SAP NetWeaver CVE-2025-31324, an unrestricted file upload (CWE-434), on 29 April, and SAP CVE-2025-42999 on 15 May, both with the known-ransomware flag (Confirmed [2][114]).

Windows CLFS and Storm-2460. Microsoft reported on 8 April that the CLFS elevation-of-privilege zero-day CVE-2025-29824 was exploited after initial compromise by Storm-2460, which used PipeMagic and went on to ransomware activity against targets in US IT and real estate, Venezuelan finance, a Spanish software

company and Saudi retail; KEV listed it that day (Confirmed [31][2]).

Oracle E-Business Suite and the Cl0p brand. GTIG says CVE-2025-61882 may have been exploited as a zero-day as early as 9 August, with suspicious activity back to 10 July, and that from 29 September an actor claiming the CL0P brand emailed executives alleging theft of E-Business Suite data (Confirmed [80]). GTIG notes overlaps with FIN11 but makes no formal attribution, names the tooling GOLDVEIN.JAVA and the SAGE chain, and publishes no ATT&CK ids (Confirmed [80]). Oracle's Security Alert (Rev 1, 4 October; Rev 2, 6 October) describes a flaw remotely exploitable without authentication that may result in remote code execution; the CVE record, published 5 October, puts it in the Concurrent Processing BI Publisher Integration of E-Business Suite 12.2.3 to 12.2.14 with CVSS 3.1 base 9.8, and CISA's ADP and NVD list CWE-287 (Confirmed [106][107][108]). KEV listed it on 6 October and Oracle's second fix, CVE-2025-61884 (patched 11 October), on 20 October, both with the known-ransomware flag (Confirmed [2][80]). The 2023 MOVEit campaign behind the same brand is told in the Cl0p file-transfer study. The software object S0611 Clop is named here for the brand only; no source opened ties Clop ransomware to the 2025 emails (Demonstrated [134]; Inferred for the caution).

GoAnywhere MFT and a Medusa affiliate. Fortra's advisory FI-2025-012 of 18 September describes a deserialization flaw in GoAnywhere MFT's License Servlet, CVE-2025-10035; KEV listed it on 29 September with the known-ransomware flag, and NVD gives CWE-502 and CWE-77 (Confirmed [93][2][114]). Microsoft's report of 6 October attributes exploitation, from 11 September, to Storm-1175, a Medusa ransomware affiliate, and saw Medusa deployed in one environment (Confirmed [94]).

Exchange hybrid. Emergency Directive 25-02 of 7 August covers CVE-2025-53786 (CWE-287), a post-authentication flaw in Exchange hybrid configurations that lets an actor with on-premises administrative access move into Exchange Online and Microsoft 365; agencies had to act by 9:00 AM EDT on 11 August (Confirmed [76]). It is not in KEV as of catalog 2026.11.10 (Confirmed [76]).

WSUS. Microsoft released an out-of-band fix on 23 October for WSUS remote code execution CVE-2025-59287 (CVSS 9.8, CWE-502); CERT-EU's advisory 2025-040 of 24 October notes a public proof of concept, and KEV listed it the same day (Confirmed [113][114]).

GeoServer at a federal agency. AA25-266A of 23 September describes a CISA incident response at a federal civilian agency compromised through GeoServer CVE-2024-36401, exploited 11 days after disclosure and about three weeks before endpoint detection alerted (Confirmed [97]).

Browsers, archives and the client side. Kaspersky's Operation ForumTroll report of 25 March describes personalized phishing links, styled as invitations to the "Primakov Readings", that infected Russian organizations from mid-March through a Chrome sandbox-escape zero-day, CVE-2025-2783; KEV listed it on 27 March (Confirmed [27]). ESET discovered on 18 July that the Russia-aligned group RomCom was exploiting the WinRAR zero-day CVE-2025-8088; it published on 11 August and KEV listed the flaw on 12 August (Confirmed [68]). GTIG's review of 2025 says that for the first time it attributed more zero-days to commercial surveillance vendors than to state espionage groups, with PRC-nexus groups behind at least 10, financially motivated groups behind 9 and North Korea behind none (Confirmed [130]). The longer story of the zero-day market is in the zero-day market study.

React Server Components. The React team disclosed CVE-2025-55182 on 3 December, an unauthenticated remote code execution flaw in React Server Components rated CVSS 10.0, reported on 29 November through Meta's bug bounty and fixed in 19.0.1, 19.1.2 and 19.2.1; KEV listed it on 5 December with the

known-ransomware flag (Confirmed [123][2]).

Other server flaws. Apache Tomcat CVE-2025-24813 (CWE-44, CWE-502, CWE-706) entered KEV on 1 April, CrushFTP CVE-2025-31161 on 7 April with the known-ransomware flag, and Erlang/OTP SSH CVE-2025-32433 (CWE-306) on 9 June (Confirmed [114][2]). The SSHole OpenSSH study is the home for OpenSSH flaws; the Erlang/OTP SSH flaw is a different implementation and is recorded here only by its KEV row (Inferred for the routing).

Part 4: China

The wider record is in the China-attributed actors study, and APT41's in the APT41 public record study. This Part gives the 2025 sequence.

Flax Typhoon and Integrity Technology Group. On 3 January Treasury sanctioned Integrity Technology Group, a Beijing company, for its support to Flax Typhoon, which the release calls a Chinese state-sponsored cyber group, over activity against US and European entities from summer 2022 to fall 2023 (Confirmed [3]). The 17 January release relays the same designation (Confirmed [4]). The library has no Flax Typhoon group object, so it stays unlinked (Demonstrated [134]). The 2024 botnet record behind the designation is in the 2024 chronicle.

Salt Typhoon, January to August. On 17 January Treasury sanctioned Sichuan Juxinhe Network Technology, which it says was directly involved in Salt Typhoon intrusions into major US telecom and internet providers, and Yin Kecheng, MSS-affiliated, over the compromise of Treasury's Departmental Offices network (Confirmed [4]). On 27 August joint advisory AA25-239A, revised 3 September and sealed by agencies of 13 countries, said PRC state-sponsored actors overlapping Salt Typhoon, OPERATOR PANDA, RedMike, UNC5807 and GhostEmperor had compromised telecom backbone and edge routers and government, transportation, lodging and military networks worldwide since at least 2021, and linked them to Sichuan Juxinhe, Beijing Huanyu Tianqiong and Sichuan Zhixin Ruijie (Confirmed [85]). It lists the exploited CVEs as CVE-2024-21887 (chained with CVE-2023-46805), CVE-2024-3400, CVE-2023-20273, CVE-2023-20198 and CVE-2018-0171, all disclosed before 2025, and says no zero-days were observed (Confirmed [85]). It maps 42 unique ATT&CK techniques, among them T1190, T1199, T1584.008, T1059.008, T1098.004, T1562.004 (now T1686), T1599, T1040, T1556, T1602.001, T1602.002, T1572, T1090.003, T1048.003, T1609, T1610, T1543.005 and T1070.009 (Confirmed [85]). ATT&CK's G1045 Salt Typhoon, modified 23 September 2026, lists OPERATOR PANDA, RedMike, GhostEmperor and UNC5807 as associated groups, while the library's `groups.jsonl` carries only "Salt Typhoon" as an alias (Confirmed [86]; Demonstrated [134]).

The contract hackers. On 5 March the DOJ charged 12 Chinese nationals: in the Southern District of New York, eight i-Soon employees and two Ministry of Public Security officers (U.S. v. Wu Haibo et al.), with hacking from about 2016 to 2023; in the District of Columbia, APT27 actors Yin Kecheng and Zhou Shuai (Confirmed [17]). The release says the hacking was done at the direction of the MPS and MSS in some cases and on the defendants' own initiative in others, names victims including the foreign ministries of Taiwan, India, South Korea and Indonesia and the US Treasury in late 2024, announces rewards of up to US$10 million and the seizure of i-Soon's primary domain; these are allegations (Confirmed [17]). Treasury sanctioned Zhou Shuai and Shanghai Heiying Information Technology the same day; its release does not name APT27 or the MSS and says only that his data requirements almost certainly originated from the CCP's intelligence services (Confirmed [18]). The DOJ release lists APT27's aliases as including Threat Group 3390, Emissary Panda, UNC 5221 and Silk Typhoon, with activity from August 2013 to December 2024, while ATT&CK maps APT27

to G0027 Threat Group-3390 (alias Linen Typhoon) and Silk Typhoon to G0125 HAFNIUM, as Microsoft does, and Mandiant treats UNC5221 as its own cluster; the conflict is in the sources and is reported here, not resolved (Inferred [17][134][19][1]).

Silk Typhoon. Microsoft's report of 5 March says Silk Typhoon (HAFNIUM, G0125), an espionage-focused Chinese state actor, shifted to the IT supply chain, compromising remote management, managed service, privileged access and cloud data vendors, used stolen API keys to reach customer tenants, abused OAuth applications and service principals to exfiltrate mail through Microsoft Graph, and exploited Ivanti CVE-2025-0282 as a zero-day in January (Confirmed [19]). On 3 July Xu Zewei was arrested in Milan; the DOJ release of 8 July alleges that, working for Shanghai Powerock Network at the direction of the MSS Shanghai State Security Bureau, he hacked COVID-19 research from February 2020 and took part in the HAFNIUM Exchange campaign of 2021, whose home study is the Exchange Marauder study (Confirmed [67]).

UNC3886 on Juniper. See Part 2. UNC3886 is G1048 in ATT&CK (Confirmed [22]; Demonstrated [134]).

SharePoint. See Part 3 and the home study. Microsoft names Linen Typhoon and Violet Typhoon as Chinese nation-state actors; ATT&CK carries the names as aliases on G0027 and G0128 (Confirmed [63]; Demonstrated [134]).

BRICKSTORM. On 4 December CISA, NSA and the Canadian Cyber Centre published a malware analysis report saying PRC state-sponsored actors use BRICKSTORM for long-term persistence, with a second report on 19 December (Confirmed [124]). ATT&CK carries S9015 BRICKSTORM (Demonstrated [134]).

UAT-9686. See Part 2 (Confirmed [125]).

The AI-orchestrated campaign, in one paragraph. The home for this event is the AI threats study. Anthropic reported on 13 November that in mid-September it detected a group it assessed with high confidence to be Chinese state-sponsored manipulating Claude Code to attempt intrusions into about thirty targets in technology, finance, chemical manufacturing and government, succeeding in a small number of cases, with the AI performing 80 to 90 percent of the tactical work; Anthropic adds that the AI at times fabricated credentials (Confirmed [103]). There is no ATT&CK group object for this actor; ATT&CK records the operation as campaign C0062 Anthropic AI-orchestrated Campaign, September 2025, under the name GTG-1002 (Demonstrated [134]).

Part 5: Russia

The wider record is in the Russia-attributed actors study, and Sandworm's in the Sandworm study.

APT28 against the aid pipeline. Joint advisory AA25-141A of 21 May says GRU 85th GTsSS unit 26165, G0007 APT28, targeted Western logistics and IT companies involved in delivering aid to Ukraine, with activity elevated since 2022, and IP cameras at Ukrainian border crossings, about 81 percent of the camera attempts being in Ukraine (Confirmed [44]). The advisory names CVE-2023-23397, WinRAR CVE-2023-38831 lures since fall 2023 and Roundcube CVEs, the HEADLACE and MASEPIE malware, and techniques including T1110.003, T1566.001, T1187, T1003.003, T1114.002, T1125 and T1090.003 (Confirmed [44]). No ATT&CK software object in the library carries HEADLACE or MASEPIE (Demonstrated [134]).

Static Tundra and FSB Center 16. The FBI's PSA of 20 August says actors attributed to FSB Center 16 exploited Cisco Smart Install CVE-2018-0171 and SNMP on end-of-life devices, collected configuration files from thousands of US critical infrastructure networking devices and showed interest in ICS protocols; the FBI

relates them to the clusters known as Berserk Bear and Dragonfly and notes Cisco's name, Static Tundra (Confirmed [82]). Talos assesses with high confidence that Static Tundra is a Russian state-sponsored espionage group, likely a sub-cluster of Energetic Bear (Berserk Bear), active for over a decade and exploiting CVE-2018-0171 since at least 2021 against telecom, higher education and manufacturing, with its Ukraine focus escalating at the start of the war (Confirmed [81]). In ATT&CK the cluster is G0035 Dragonfly, whose aliases include Berserk Bear and Energetic Bear; the binding of Static Tundra to G0035 follows the FBI's and Talos's relation and treats Static Tundra as a sub-cluster, not an alias (Demonstrated [134]; Inferred for the binding).

Secret Blizzard in Moscow. Microsoft's report of 31 July says Secret Blizzard, which Microsoft notes CISA attributes to FSB Center 16, used an adversary-in-the-middle position at the internet service provider level in Moscow, likely enabled by lawful intercept systems, to deliver ApolloShadow to foreign embassies; ApolloShadow installs trusted root certificates (Confirmed [73]). In the library Secret Blizzard is an alias of G0010 Turla; ApolloShadow has no ATT&CK software object (Demonstrated [134]).

OAuth phishing. Volexity's report of 22 April is titled for Russian threat actors phishing Microsoft 365 OAuth authorization codes; only the title and date were checked, so no actor or technique is bound to it here (Confirmed [34]).

RomCom and WinRAR. See Part 3 (Confirmed [68]). RomCom has no ATT&CK object in the library (Demonstrated [134]).

PathWiper. Talos reported on 5 June that the PathWiper destructive attack hit a Ukrainian critical infrastructure entity and was pushed through a legitimate endpoint administration framework; it attributes the attack with high confidence to a Russia-nexus APT and notes similarity to HermeticWiper, which ATT&CK carries as S0697 (Confirmed [50]; Demonstrated [134]). PathWiper itself has no ATT&CK object (Demonstrated [134]).

Hacktivists and OT. AA25-343A, last revised on 18 December, says the pro-Russia hacktivist groups CARR, Z-Pentest, NoName057(16) and Sector16 use minimally secured, internet-facing VNC to reach OT in water, food and agriculture, and energy, with impacts that include physical damage (Confirmed [126]). The home for this record is the ICS attacks and advisories study; Part 10 gives the year's OT sequence. **Poland, December 2025, in one paragraph.** ATT&CK records destructive attacks on Polish energy infrastructure in December 2025 as campaign C0063 2025 Poland Wiper Attacks, with no group associated; the attack and its disputed attribution are told in the ICS attacks and advisories study and the Russia-attributed actors study (Demonstrated [134]).

Part 6: Iran and North Korea

The wider records are in the Iran-attributed actors study and the North Korea-attributed actors study.

Iran. On 30 June CISA, the FBI, DC3 and NSA warned that Iranian state-sponsored or affiliated actors and hacktivists may target vulnerable US networks and that activity was expected to escalate, singled out defense industrial base firms with ties to Israeli research and defense firms, and said no coordinated Iranian campaign had been observed in the US at that time (Confirmed [58]).

Bybit, in one paragraph. The home for this event is the North Korea-attributed actors study. The FBI's PSA of 26 February says North Korea was responsible for the theft of about US$1.5 billion in virtual assets from the

Bybit exchange on or about 21 February, and calls the activity TraderTraitor; it does not say Lazarus (Confirmed [14]). Chainalysis reports that Bybit unknowingly signed a malicious transaction during a routine transfer from cold to hot wallet, letting the attackers move about 401,000 ETH, which it calls the largest digital heist in crypto history, laundered through intermediary wallets, swaps, bridges and dormancy (Reported [15]). TraderTraitor is not an alias of any ATT&CK group in the library, so this study binds no group; mapping it to G0032 Lazarus Group on this source would go beyond what the FBI said (Demonstrated [134]; Inferred for the caution).

The IT workers. On 30 June the DOJ announced coordinated nationwide actions against North Korean remote IT worker schemes: two indictments, an information with a plea, the arrest of Zhenxing Wang, searches of suspected laptop farms, and the seizure of 29 financial accounts and of websites; it says the schemes were designed to evade sanctions and fund the regime's illicit programs; these are allegations (Confirmed [59]). The release gives conflicting counts (see the discrepancies). Anthropic's August report names North Korean IT-worker fraud using AI among its cases (Confirmed [75]).

Part 7: identity, SaaS and the help desk

The series' cloud security incidents study is the intended home for the SaaS incidents below; until it reaches the library, this Part carries the record.

UNC6040 and the Salesforce vishing campaign. GTIG reported on 4 June that UNC6040 used voice phishing to persuade staff to authorize a modified version of Salesforce's Data Loader connected app and then exfiltrated Salesforce data, with follow-on extortion by UNC6240, which claims to be ShinyHunters; its update of 5 August says one of Google's own corporate Salesforce instances, holding contact data for small and medium businesses, was hit by similar activity in June (Confirmed [56]). The FBI's FLASH-20250912-001 of 12 September, coordinated with CISA, published indicators for UNC6040, which it says has vished call centres since October 2024, and for UNC6395 (Confirmed [90]). ATT&CK records the campaign as C0059 Salesforce Data Exfiltration, October 2024 to September 2025, citing the FBI and Google reports, and the library carries UNC6240 as an alias of G1057 ShinyHunters (Demonstrated [134]).

UNC6395 and the Salesloft Drift tokens. GTIG's report of 26 August says that from as early as 8 August through at least 18 August UNC6395 used compromised OAuth tokens of the Salesloft Drift app to export large volumes of data from numerous corporate Salesforce instances and searched it for secrets such as AWS keys, passwords and Snowflake tokens; the tokens were revoked on 20 August, and GTIG says this was not a vulnerability in the Salesforce platform (Confirmed [78]). Its update of 28 August adds that Drift Email OAuth tokens were also compromised and that on 9 August the actor read email in a very small number of Google Workspace accounts integrated with Drift (Confirmed [78]). GTIG's mitigations are to revoke and rotate integration tokens, scope connected apps to the least access they need and apply IP restrictions (Confirmed [78]). UNC6395 has no ATT&CK object in the library (Demonstrated [134]).

Commvault Metallic. CISA said on 22 May that actors may have accessed client secrets for Commvault's Metallic Microsoft 365 backup SaaS hosted in Azure, giving access to customers' Microsoft 365 environments, possibly as part of a wider campaign against SaaS applications; CVE-2025-3928 is in KEV (Confirmed [46]).

Oracle's legacy cloud. On 16 April CISA issued guidance on credential risks from potential unauthorized access to a legacy Oracle cloud environment, stating that scope and impact remained unconfirmed (Confirmed [33]).

Scattered Spider. CISA and the FBI updated AA23-320A on 29 July with new TTPs: impersonating staff to the help desk to reset passwords and MFA (printed as T1656, now T1684.001, and T1566.004), voice reconnaissance (T1598.004), trusted relationships (T1199), domain accounts (T1078.002), email collection (T1114), exfiltration over web services (T1567, T1567.002), proxies (T1090) and DragonForce ransomware against VMware ESXi (T1486), plus Snowflake data theft; the table also carries T1621, T1556.006, T1606, T1539, T1021.007, T1530 and T1219, and Mobile ids T1660 and T1451 (Confirmed [72]). Its mitigations are phishing-resistant MFA (FIDO/WebAuthn or PKI), allowlisting of remote access tools, offline immutable backups and, new in 2025, monitoring of risky logins; it gives no detailed help-desk verification procedure (Confirmed [72]). On 18 September the DOJ unsealed a complaint against UK national Thalha Jubair, alleging about 120 intrusions from May 2022 to September 2025, at least 47 US victims and over US$115 million in ransom paid (Confirmed [92]). In ATT&CK the group is G1015 Scattered Spider (Demonstrated [134]). The UK NCA arrested four people on 10 July, two aged 19, one 17 and one 20, over the April attacks on M&S, Co-op and Harrods; the opened release does not name Scattered Spider, so no group is tied to those attacks here (Confirmed [62]).

Insiders and vendors. Coinbase's 8-K of 15 May says it received an extortion email on 11 May from an actor who had obtained customer and internal data by paying overseas support contractors or employees; Coinbase did not pay and estimated US$180 million to US$400 million in remediation and reimbursement costs (Confirmed [39]). Discord said on 3 October, updated 9 October, that its customer-service vendor 5CA was compromised, that about 70,000 users may have had government-ID photos exposed and that the actor sought a ransom (Confirmed [105]). Red Hat said on 2 October that an unauthorized third party accessed and copied data from a GitLab instance used by Red Hat Consulting that held consulting engagement data (Confirmed [104]). SonicWall's cloud backup incident is in Part 2 (Confirmed [91]).

Cloud-native destruction. Microsoft reported on 27 August that Storm-0501 (G1053) had shifted to cloud-based ransomware, exfiltrating data and destroying data and backups in victims' cloud environments with cloud-native capabilities, without deploying traditional ransomware (Confirmed [87]; Demonstrated [134]).

Exposed data. Wiz Research found a publicly accessible, unauthenticated DeepSeek ClickHouse database exposing over a million log lines, including chat history and secret keys, published on 29 January (Confirmed [8]).

Social engineering of executives and officials. CISA relayed on 6 March an FBI warning of a data-extortion scam targeting corporate executives; only the title and date were checked (Confirmed [20]). The FBI's PSA of 19 December, updating one of 15 May, warns of ongoing impersonation of senior US officials through smishing and vishing that may use AI-generated voices (Confirmed [127]).

Part 8: ransomware, extortion and the money

The ransomware ecosystem study traces these groups across seven years; this Part gives the 2025 record.

The ransomware advisories of 2025. Each is a CISA advisory, most of them joint with the FBI and partners; their technique ids are bound in Part 15.

- **Ghost (Cring), AA25-050A, 19 February.** Initial access through old CVEs (CVE-2018-13379, CVE-2010-2861, CVE-2009-3960, CVE-2019-0604 and the 2021 ProxyShell set); techniques include T1190, T1505.003, T1068, T1134.001, T1562.001 (now T1685), T1003, T1486 and T1490 (Confirmed [13]). Ghost has no ATT&CK object in the library (Demonstrated [134]).

- **Medusa, AA25-071A, 12 March (FBI, CISA and MS-ISAC; HHS added as a co-sealer in the August 2026 update).** TTPs as of February 2025; the live page, last updated 18 August 2026, says over 500 victims as of April 2026 across medical, education, legal, insurance, technology and manufacturing, and now uses ATT&CK v20 naming (the Stealth tactic and T1685); techniques include T1190, T1566, T1072, T1047, T1675, T1484.001, T1003.001, T1558, T1219, T1567.002, T1486, T1490, T1489, T1529, T1657, T1006 and T1564.012 (Confirmed [23]). ATT&CK carries G1051 Medusa Group and S1244 Medusa Ransomware (Demonstrated [134]).
- **Play, AA23-352A updated 4 June.** About 900 affected entities as of May 2025, SimpleHelp CVE-2024-57727 exploited for access, an ESXi variant, and T1059.001 added; techniques include T1078, T1190, T1133, T1562.001 (now T1685), T1070.001 (now T1685.005), T1484.001, T1486 and T1657 (Confirmed [49][48]). ATT&CK carries G1040 Play and S1162 Playcrypt (Demonstrated [134]).
- **SimpleHelp, AA25-163A, 12 June.** Ransomware actors exploited unpatched SimpleHelp RMM to compromise customers of a utility billing software provider (Confirmed [54]).
- **Interlock, AA25-203A, 22 July.** Active since September 2024 against businesses and critical infrastructure in North America and Europe, with the NodeSnake RAT as of March 2025; drive-by compromise (T1189), fake updates and the "ClickFix" technique (T1204.004 Malicious Copy and Paste) and double extortion (T1486, T1567.002), with T1547.001, T1036.005, T1218.011, T1555.003, T1056.001, T1558.003, T1021.001, T1530, T1219, T1048 and T1657 (Confirmed [69]). Interlock has no ATT&CK object in the library (Demonstrated [134]).
- **Akira, AA24-109A updated 13 November.** Adds SonicWall CVE-2024-40766, Veeam CVE-2024-40711 and CVE-2023-27532, VMware ESXi CVE-2024-37085, encryption of Nutanix AHV disks in a June 2025 incident, exfiltration in about two hours and about US$244.17 million in claimed proceeds as of late September 2025; techniques include T1133, T1110.003, T1550.002, T1482, T1537, T1567.002, T1486 and T1490 (Confirmed [120]). ATT&CK carries G1024 Akira and S1129 Akira (Demonstrated [134]).

What the IC3 saw. The FBI's IC3 2025 report counts over 3,600 ransomware complaints and losses over US$32 million, excluding downtime and remediation; its top variants were Akira, Qilin, INC/Lynx/Sinobi, BianLian, Play, RansomHub, LockBit, DragonForce, SafePay and Medusa, and it counted 63 new variants (Confirmed [131]). Chainalysis, published on 5 February, estimated 2024 ransomware payments at about US$813.55 million, down 35% from US$1.25 billion in 2023 (Reported [16]). Verizon's 2025 DBIR release puts ransomware in 44% of breaches, a median ransom paid of US$115,000 and 64% of victims not paying (Reported [36]).

Victims who filed. Form 8-K filings, several under the SEC's Item 1.05 rule, put dates on the year's disruptions. Conduent (13 Jan), Lee Enterprises (3 Feb), Sensata (6 Apr), DaVita (12 Apr), Nucor (13 May), UNFI (5 Jun), Erie (7 Jun), Aflac (12 Jun), Alaska Air Group for Hawaiian Airlines (23 Jun), Ingram Micro (5 Jul), F5 (9 Aug) and RTX for Collins' MUSE (19 Sep) all filed (Confirmed [5][10][30][32][40][51][52][55][57][61][79][95]). Lee Enterprises, Sensata, DaVita, Ingram Micro and RTX name ransomware or encryption; Aflac says its incident was not ransomware; none names an actor (Confirmed [10][30][32][61][95][55]). JLR, not an SEC filer, said on 2 September it had shut down systems after a cyber incident, with retail and production severely disrupted and no evidence of customer data theft at that stage (Confirmed [88]).

Exploits that fed ransomware. Storm-2460's CLFS zero-day (April), Storm-2603's Warlock deployments through SharePoint (July) and Storm-1175's GoAnywhere access leading to Medusa (September) were each

documented by Microsoft (Confirmed [31][63][94]). KEV's known-ransomware flag marks 31 of the 2025 additions, including Ivanti CVE-2025-0282, FortiOS CVE-2024-55591 and CVE-2025-24472, CrushFTP, CLFS, SAP NetWeaver, Citrix CVE-2025-5777, the SharePoint chain, GoAnywhere, Oracle EBS and React (Confirmed [2]).

Arrests and takedowns. On 10 February the DOJ unsealed charges against Roman Berezhnoy and Egor Glebov, arrested in a coordinated international action, for Phobos affiliate activity under the 8Base name: over 1,000 victims and over US$16 million in ransoms; the Bavarian LKA seized the 8Base site and over 100 servers were disrupted; the action follows the arrest and extradition of Phobos administrator Evgenii Ptitsyn (Confirmed [11]). The second phase of Operation Endgame, 19 to 22 May, took down about 300 servers, neutralised 650 domains, issued 20 international arrest warrants and seized EUR 3.5 million (over EUR 21.2 million across Endgame), against Bumblebee, Latrodectus, Qakbot, HijackLoader, DanaBot, Trickbot and Warmcookie (Confirmed [45]). ATT&CK carries S1039 Bumblebee, S1160 Latrodectus, S0650 QakBot and S0266 TrickBot; DanaBot, HijackLoader and WarmCookie are not in the library's data (Demonstrated [134]). Endgame's November phase, 10 to 14 November, took down or disrupted over 1,025 servers and seized 20 domains, against Rhadamanthys, VenomRAT and the Elysium botnet (Confirmed [117]). The IC3 report records DOJ disruption actions against BlackSuit (Royal) on 11 August; ATT&CK carries Royal as S1073 (Confirmed [131]; Demonstrated [134]).

Lumma. Microsoft's Digital Crimes Unit says that between 16 March and 16 May over 394,000 Windows computers were infected by Lumma, and that about 2,300 domains were seized under a court order from the Northern District of Georgia while the DOJ seized Lumma's central command structure, with Europol's EC3 and Japan's JC3 taking part (Confirmed [41]). The DOJ release says five LummaC2 domains were seized on 19 and 20 May and cites at least 1.7 million instances of LummaC2 data theft (Confirmed [42]). AA25-141B, released the same day, gives LummaC2's TTPs and indicators (Confirmed [43]). ATT&CK carries it as S1213 Lumma Stealer (Demonstrated [134]).

The money rails. On 6 and 7 March the DOJ, with Germany and Finland, took down Garantex infrastructure and charged two administrators (Confirmed [21]). On 14 August OFAC re-designated Garantex, designated its successor Grinex, three executives and six companies, said Garantex had received proceeds of Conti, Black Basta, LockBit, NetWalker and Phoenix Cryptolocker, and noted over US$26 million frozen on 6 March (Confirmed [77]). ATT&CK carries S0575 Conti, S1070 Black Basta, S0457 Netwalker and S1202 LockBit 3.0; the LockBit version binding is this study's (Demonstrated [134]; Inferred for the version). Bulletproof hosts were sanctioned three times: Zservers for supporting LockBit (11 Feb, with Australia and the UK), Aeza Group (1 Jul) and Media Land for supporting ransomware (19 Nov, with Australia and the UK) (Confirmed [12][60][121]). OFAC also sanctioned Funnull Technology on 29 May for hosting the infrastructure behind pig-butchering scams with over US$200 million in US victim-reported losses (Confirmed [47]).

The payment ban. On 22 July the UK government said its ransomware measures would go ahead after consultation: a ban on ransom payments by public sector bodies and operators of critical national infrastructure, a payment-notification regime for other organizations and mandatory incident reporting (Confirmed [70]).

Part 9: supply chain and the build pipeline

The home for the npm compromises is the npm supply-chain study; the earlier history of model-hub supply chain risk is in the Hugging Face supply chain study, and of build-system compromise in the SolarWinds study.

tj-actions and reviewdog. CISA's alert of 18 March, updated 19 and 26 March, says tj-actions/changed-files was compromised (CVE-2025-30066), with all versions affected from 12 March 00:00 UTC to 15 March 12:00 UTC, possibly enabled by the compromise of reviewdog/action-setup@v1 (CVE-2025-30154) between 18:42 and 20:31 UTC on 11 March; exposed secrets included access keys, GitHub personal access tokens, npm tokens and private RSA keys, and both CVEs were in KEV by the 26 March revision (Confirmed [25]). StepSecurity's Harden-Runner detected the compromise; it dates the start to about 16:00 UTC on 14 March, says public repositories were leaking secrets in build logs and puts the action's use at over 23,000 repositories (Confirmed [24]). The CVE records list both as CWE-506, embedded malicious code; CVE-2025-30066 was published on 15 March (Confirmed [26]).

Amazon Q Developer. AWS bulletin AWS-2025-015 says an inappropriately scoped GitHub token in a CodeBuild configuration let a threat actor commit malicious code to the open-source repository of the Amazon Q Developer extension for VS Code, which was automatically included in release v1.84 (CVE-2025-8217) (Confirmed [71]).

Nx, debug and chalk, and Shai-Hulud, in one paragraph. Nx's advisory GHSA-cxm3-wv7p-598c says malicious versions of the nx package and supporting plugins scanned file systems, collected credentials and posted them to GitHub repositories named s1ngularity-repository in victims' own accounts (Confirmed [84]). Snyk reports that eight malicious Nx releases were live on npm for about 5h20m on 26 and 27 August UTC, abused AI coding command-line tools, and traced to a flawed GitHub Actions workflow contributed on 21 August (Reported [83]); it also reports that on 8 September an npm maintainer was phished from a lookalike support domain and malicious versions of popular packages including debug and chalk were published (Reported [89]). CISA's alert of 23 September says the self-replicating Shai-Hulud worm compromised over 500 npm packages, harvested GitHub tokens and AWS, GCP and Azure keys, and republished tainted versions with victims' npm access, and asks for pinning to releases before 16 September, rotation of developer credentials and phishing-resistant MFA on GitHub and npm (Confirmed [96]). GitLab reported on 24 November a renewed Shai-Hulud campaign with the same credential harvesting and worm-style republishing and a destructive fallback that deletes user files if the host loses access to both GitHub and npm (Confirmed [122]). ATT&CK carries S9008 Shai-Hulud, first reported in September 2025, and S9043 Mini Shai-Hulud, a 2026 derivative (Demonstrated [134]).

F5's source code. The F5 theft is often framed as a software supply chain compromise, but F5 reports, with NCC Group and IOActive, no evidence that its source, build or release pipelines were modified; it is a theft of source code and vulnerability knowledge, whose risk is future exploitation, not a poisoned update (Confirmed [112]; Inferred for the framing).

The pattern. Across 2025, the supply chain cases that reached victims turned on two things: SaaS-to-SaaS OAuth trust (Drift, Commvault Metallic) and token scoping in CI (tj-actions, Amazon Q, Nx) (Inferred [78][46][25][71][83]).

Part 10: industrial and critical infrastructure

The home for the year's industrial record is the ICS attacks and advisories study; the earliest ICS precedent in this series is the Stuxnet study.

On 6 May CISA warned that unsophisticated actors were targeting ICS and SCADA in US oil and natural gas, energy and transportation systems, and CISA, the FBI, EPA and DOE issued the fact sheet Primary Mitigations to Reduce Cyber Threats to Operational Technology (Confirmed [37][38]). Talos's PathWiper report of 5 June describes a destructive attack on a Ukrainian critical infrastructure entity (Confirmed [50]). The 30 June fact sheet on Iranian actors names critical infrastructure among the possible targets (Confirmed [58]). AA25-212A of 31 July, from CISA and the US Coast Guard, reports findings from a proactive hunt at a US critical infrastructure organization; its first-listed mitigation is to stop storing credentials in plaintext (Confirmed [74]). The FBI says the FSB Center 16 actors behind Static Tundra showed interest in ICS protocols on the devices whose configurations they collected (Confirmed [82]). AA25-343A says pro-Russia hacktivists reached OT in water, food and agriculture, and energy through minimally secured internet-facing VNC, with impacts including physical damage (Confirmed [126]). RTX's 8-K on Collins' MUSE passenger-processing software and JLR's production shutdown show IT intrusions stopping physical operations outside the OT estate (Confirmed [95][88]; Inferred for the reading). The destructive attacks on Polish energy infrastructure in December, recorded by ATT&CK as C0063 2025 Poland Wiper Attacks, are summarized in Part 5 and told in the home study (Demonstrated [134]).

Part 11: AI and the attacker

The home for this record is the AI threats study.

Anthropic's August threat report describes a data-extortion operation scaled with Claude Code, which it calls "vibe hacking", and North Korean IT-worker fraud using AI; only the headlines were checked (Confirmed [75]). Its report of 13 November describes the AI-orchestrated espionage campaign told in Part 4 (Confirmed [103]). GTIG reported on 5 November the first malware families it had identified that use large language models during execution to generate or rewrite code, PROMPTFLUX and PROMPTSTEAL (Confirmed [116]). The library carries PROMPTSTEAL as an alias of S9035 LAMEHUG, which CERT-UA first identified in July 2025 in phishing against Ukrainian government officials (Demonstrated [134]). The FBI's December PSA warns that impersonation of senior officials may use AI-generated voices (Confirmed [127]). DeepSeek's exposed database in January was an exposure at an AI company, not an attack using AI (Confirmed [8]; Inferred for the distinction).

Part 12: the government record

Directives. ED 25-02 (Exchange hybrid, 7 Aug), ED 25-03 (Cisco ASA and Firepower, 25 Sep, with implementation guidance on 12 Nov) and ED 26-01 (F5, 15 Oct) (Confirmed [76][98][119][111]).

Executive orders. Executive Order 14144, signed on 16 January, directs FAR contract language for machine-readable secure software development attestations submitted through CISA's repository for software attestations and artifacts (Confirmed [7]). Executive Order 14306, signed on 6 June, amends EO 13694 and EO 14144: it strikes several sections of EO 14144, narrows EO 13694 sanctions to foreign persons, and sets a post-quantum product list by 1 December 2025, TLS 1.3 by 2 January 2030, an SSDF update by 1 December

2025 and Cyber Trust Mark rules by 4 January 2027 (Confirmed [53]).

Sanctions. Integrity Technology Group (3 Jan); Sichuan Juxinhe and Yin Kecheng (17 Jan); Zservers (11 Feb); Zhou Shuai and Shanghai Heiying (5 Mar); Funnull (29 May); Aeza Group (1 Jul); Garantex, Grinex and associates (14 Aug); Media Land (19 Nov) (Confirmed [3][4][12][18][47][60][77][121]).

Charges and arrests. 8Base (10 Feb); 12 Chinese contract hackers and officers (5 Mar); Garantex administrators (7 Mar); North Korean IT worker schemes (30 Jun); Xu Zewei (3 Jul); four arrests over UK retail attacks (10 Jul); Thalha Jubair (18 Sep) (Confirmed [11][17][21][59][67][62][92]).

Takedowns. Garantex (Mar), Lumma (May), Operation Endgame (May and November), BlackSuit (Aug, per IC3) (Confirmed [21][41][42][45][117][131]).

Advisories and alerts. CISA and partners published the year's #StopRansomware advisories (Ghost, Medusa, Interlock, and updates for Play, Scattered Spider and Akira), advisories on the Ivanti CSA chain, LummaC2, GRU unit 26165, SimpleHelp, the Salt Typhoon-linked backbone campaign, GeoServer, a critical infrastructure hunt and pro-Russia hacktivists, the Fast Flux advisory, a BRICKSTORM malware analysis and alerts on tj-actions, Commvault, Oracle's legacy cloud and Shai-Hulud (Confirmed [13][23][69][49][72][120][9][43][44][54][85][97][74][126][29][124][25][46][33][96]).

The UK. The ransomware payment measures (22 Jul), the NCSC Annual Review (14 Oct), and the Cyber Security and Resilience (Network and Information Systems) Bill, introduced for first reading on 12 November (Confirmed [70][109][118]). The NCSC review, covering 1 September 2024 to 31 August 2025, reports 1,727 tips, 429 incidents handled, 204 (48%) nationally significant against 89 the year before, and 18 (4%) highly significant, a 50% rise and the third annual increase in a row; the NCSC says its data understates incidents because reporting is often not mandatory (Confirmed [110]).

The UN. The UN Convention against Cybercrime, adopted by the General Assembly on 24 December 2024, opened for signature in Hanoi on 25 October 2025 and enters into force once 40 States are Parties (Confirmed [115]).

Part 13: the numbers

Measure	2025	Comparison	Source
KEV entries added	245	186 in 2024	Confirmed [2]
KEV additions with CVE-2025 ids	151	94 older, 23 pre-2020	Confirmed [2]; Demonstrated
KEV additions now flagged for known ransomware use	31	Flag is current, not as of listing	Confirmed [2]
CVE records with a 2025 published date (NVD)	49,972	Q1 12,412; Q2 12,205; Q3 12,207; Q4 13,148	Confirmed [129]
Zero-days exploited in the wild (GTIG)	90	78 in 2024, 100 in 2023	Confirmed [130]
Share against enterprise software and appliances (GTIG)	48% (43)	Highest on record	Confirmed [130]
UK nationally significant incidents (NCSC, Sep 2024 to Aug 2025)	204	89 the year before	Confirmed [110]
Ransomware complaints to IC3	Over 3,600	Losses over US$32 million, excluding downtime and remediation	Confirmed [131]
Breaches with third-party involvement (Verizon DBIR)	30%	About double	Reported [36]
Initial access through vulnerability exploitation (Verizon DBIR)	20%	Up 34%	Reported [36]

Part 14: the defender view

Patch the edge, then prove the patch. ED 25-03 asked for core dumps within a day and, in its April 2026 update, a hard power removal; CISA's November guidance found organizations that thought they were patched but were below the minimum fixed versions (Confirmed [98][119]). Mandiant's Ivanti guidance is to run both integrity checks, factory reset on any failure, and reset credentials, API keys and certificates, keeping logs off the device (Confirmed [1]). ED 26-01 adds disconnecting public-facing devices past end of support (Confirmed [111]).

Isolate the management plane. AA25-239A asks defenders to patch edge devices first, isolate the management plane with out-of-band networks or a management VRF and default-deny access lists, use SNMPv3 with authentication and privacy only, disable Smart Install and Guest Shell, use Type 8 passwords, send logs to a central immutable store with AAA accounting, and check configuration baselines and firmware integrity (Confirmed [85]).

Govern integrations like accounts. Revoke and rotate integration tokens, scope connected apps to the least access they need and restrict them by IP (GTIG, on Drift); rotate vendor-held client secrets when the vendor reports an incident, the lesson of the Commvault alert (Confirmed [78][46]; Inferred for the rotation advice).

Harden the help desk. Phishing-resistant MFA, allowlisting of remote access tools and monitoring of risky logins are AA23-320A's asks; the help-desk identity check itself is left to the organization (Confirmed [72];

Inferred for the gap).

Pin the pipeline. Pin packages to known-safe releases and put phishing-resistant MFA on GitHub and npm (Confirmed [96]); rotate any secret that could have reached a build log (Confirmed [25]); pin third-party actions to full commit SHAs as well, which is our inference and not an ask in any opened CISA alert (Inferred). Scope CI tokens to the job (AWS's root cause) (Confirmed [71]).

Protect the servers attackers reach after the edge. Microsoft's SharePoint mitigations are AMSI in Full Mode, Defender antivirus, rotation of ASP.NET machine keys and an IIS restart (Confirmed [63]). Stop storing credentials in plaintext, AA25-212A's first mitigation (Confirmed [74]).

Keep recovery out of the attacker's reach. Offline, immutable backups appear in AA23-320A's mitigations; Storm-0501 shows that backups reachable by a compromised cloud identity can be destroyed with the data (Confirmed [72][87]; Inferred for the reading).

Hunting cues from the record. At the advisory level, and without commands. Each cue is this study's reading of a behavior the sources describe (behaviors Confirmed; cues Inferred):

- Edge appliances: integrity-check failures or tampered manifests on VPN gateways, configuration exports from routers and firewalls, SNMP queries from unexpected sources, and new containers or Guest Shell use on network devices (Confirmed [1][85][82]).
- Firmware: devices that keep an implant across reboot and upgrade; compare running images and ROM against known-good (Confirmed [98][99]).
- SaaS: new or modified connected apps, bulk API exports from CRM tenants, and integration tokens used from unfamiliar IP ranges (Confirmed [56][78]).
- Help desk: password and MFA resets requested by phone, followed by new device registrations (Confirmed [72]).
- CI: workflows that print secrets, unpinned third-party actions, and new repositories created in developer accounts after a package install (Confirmed [25][84]).
- Ransomware precursors: Group Policy changes that push software, ESXi administration commands, and new remote access tools (Confirmed [63][23][69]).

Exposure management. See the library's Vulnerability Prioritization Reference, Edge Device Security Reference, Identity Security Reference, Cloud Attack Reference and Ransomware Defense Reference.

Part 15: MITRE mappings

This Part binds the verified 2025 record to MITRE ATT&CK v20.0, CWE, CAPEC and D3FEND, with every id checked against the library's data files (`data/attack/technique_profiles.jsonl`, `data/attack/superseded_by.jsonl`, `data/attack/groups.jsonl`, `software.jsonl`, `campaigns.jsonl`, `campaign_profiles.jsonl`, `data/attack/ics/technique_profiles.jsonl`, `data/attack/technique_to_d3fend.jsonl`, `data/attack/d3fend_countermeasures.jsonl`, `data/weaknesses/cwe.jsonl` and `data/weaknesses/capec.jsonl`) and the generated pages under `mitre/` on 11 November 2026 (Demonstrated [133][132][134][139][136][135]). Tactic names follow ATT&CK v20.0, which splits the former Defense Evasion tactic into Stealth and Defense Impairment.

Each row carries a basis. **Source** means an opened advisory or the ATT&CK record prints the ATT&CK id itself. **Behavior** means the source describes the behavior and this study assigns the id (the behavior is Confirmed; the mapping is this study's reading). **Inferred** means the id rests on this study's reading of a source that lists no ids. The advisories' printed ids were resolved against v20.0: T1562.001 is revoked into T1685 Disable or Modify Tools, T1562.004 into T1686 Disable or Modify System Firewall, T1656 into T1684.001 Impersonation, and T1070.001 into T1685.005 Clear Windows Event Logs (Demonstrated [132]). "C0058 record" and "C0059 record" are the ATT&CK campaign records for SharePoint ToolShell Exploitation (July 2025) and Salesforce Data Exfiltration (October 2024 to September 2025) in the library's `campaign_profiles.jsonl` (Demonstrated [134]; Confirmed [66]).

ATT&CK Enterprise techniques

Id	Name	Tactic (v20.0)	Where it appears in the 2025 record	Basis	Source
T1595.002	Vulnerability Scanning	Reconnaissance	C0058 record (Jul)	Source	[66][134]
T1598.004	Spearphishing Voice	Reconnaissance	AA23-320A update (29 Jul); C0059 record; UNC6040 vishing (GTIG, 4 Jun)	Source; Behavior	[72][134][56]
T1583.001	Domains	Resource Development	C0058 record	Source	[134]
T1584.008	Network Devices	Resource Development	AA25-239A (27 Aug)	Source	[85]
T1585	Establish Accounts	Resource Development	C0059 record	Source	[134]
T1585.002	Email Accounts	Resource Development	C0058 and C0059 records	Source	[134]
T1586.002	Email Accounts	Resource Development	C0059 record	Source	[134]
T1587.001	Malware	Resource Development	C0059 record (the modified Data Loader app)	Source	[134][56]
T1588.002	Tool	Resource Development	C0058 and C0059 records	Source	[134]
T1608.005	Link Target	Resource Development	C0059 record	Source	[134]
T1190	Exploit Public-Facing Application	Initial Access	AA25-239A, AA25-050A, AA25-071A and AA23-352A tables; Microsoft's SharePoint report and the C0058 record; Ivanti (Jan, Apr), FortiOS (Jan), Cisco ASA (Sep), Oracle EBS (Aug to Oct), GoAnywhere (Sep), GeoServer (AA25-266A) and Static Tundra as Behavior	Source; Behavior	[85][13][23][49][63][134][1][28][6][98][80][94][97][82]
T1133	External Remote Services	Persistence, Initial Access	AA24-109A update (13 Nov); AA23-352A update (4 Jun)	Source	[120][49]
T1078	Valid Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	AA23-352A update	Source	[49]

Id	Name	Tactic (v20.0)	Where it appears in the 2025 record	Basis	Source
T1078.002	Domain Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	AA23-320A update; C0059 record	Source	[72][134]
T1189	Drive-by Compromise	Initial Access	AA25-203A (Interlock, 22 Jul)	Source	[69]
T1199	Trusted Relationship	Initial Access	AA25-239A and AA23-320A update; Discord's vendor 5CA (Oct) as Behavior; Salesloft Drift (Aug) as Inferred	Source; Behavior; Inferred	[85][72][105][78]
T1566	Phishing	Initial Access	AA25-071A	Source	[23]
T1566.001	Spearphishing Attachment	Initial Access	AA25-141A (21 May); AA25-141B (21 May)	Source	[44][43]
T1566.002	Spearphishing Link	Initial Access	AA25-141B; ForumTroll's personalized links (Kaspersky, 25 Mar) as Behavior	Source; Behavior	[43][27]
T1566.004	Spearphishing Voice	Initial Access	AA23-320A update (help-desk calls)	Source	[72]
T1195.001	Compromise Software Dependencies and Development Tools	Initial Access	tj-actions and reviewdog (Mar), Nx (Aug), Shai-Hulud (Sep, Nov)	Behavior	[25][84][96][122]
T1195.002	Compromise Software Supply Chain	Initial Access	Amazon Q Developer extension v1.84 (Jul)	Behavior	[71]
T1059.001	PowerShell	Execution	Microsoft's SharePoint report; AA23-352A update; C0058 record	Source	[63][49][134]
T1059.003	Windows Command Shell	Execution	C0058 record	Source	[134]
T1059.006	Python	Execution	C0059 record	Source	[134]
T1059.008	Network Device CLI	Execution	AA25-239A	Source	[85]
T1047	Windows Management Instrumentation	Execution	Microsoft's SharePoint report; AA25-071A; C0058 record	Source	[63][23][134]
T1053.005	Scheduled Task	Execution, Persistence, Privilege Escalation	C0058 record	Source	[134]
T1072	Software Deployment Tools	Execution, Lateral Movement	AA25-071A; PathWiper pushed through an endpoint administration framework (Talos, 5 Jun) as Behavior	Source; Behavior	[23][50]

Id	Name	Tactic (v20.0)	Where it appears in the 2025 record	Basis	Source
T1106	Native API	Execution	AA25-141B (filed there under Exfiltration)	Source	[43]
T1204.004	Malicious Copy and Paste	Execution	AA25-203A	Source	[69]
T1569.002	Service Execution	Execution	C0058 record	Source	[134]
T1609	Container Administration Command	Execution	AA25-239A	Source	[85]
T1610	Deploy Container	Execution	AA25-239A	Source	[85]
T1675	ESXi Administration Command	Execution	AA25-071A	Source	[23]
T1098.004	SSH Authorized Keys	Persistence, Privilege Escalation	AA25-239A	Source	[85]
T1136.001	Local Account	Persistence	AA25-239A	Source	[85]
T1505.003	Web Shell	Persistence	Microsoft's SharePoint report; AA25-050A; C0058 record	Source	[63][13][134]
T1505.004	IIS Components	Persistence	Microsoft's SharePoint report; C0058 record	Source	[63][134]
T1543.005	Container Service	Persistence, Privilege Escalation	AA25-239A	Source	[85]
T1547.001	Registry Run Keys / Startup Folder	Persistence, Privilege Escalation	AA25-203A	Source	[69]
T1556	Modify Authentication Process	Defense Impairment, Persistence, Credential Access	AA25-239A	Source	[85]
T1556.006	Multi-Factor Authentication	Defense Impairment, Persistence, Credential Access	AA23-320A update table	Source	[72]
T1671	Cloud Application Integration	Persistence	C0059 record (the connected app UNC6040 had staff authorize)	Source	[134][56]
T1542.001	System Firmware	Stealth, Persistence	ASA read-only memory altered to persist through reboot and upgrade (ED 25-03, 25 Sep)	Behavior	[98]
T1068	Exploitation for Privilege Escalation	Privilege Escalation	AA25-050A; the CLFS zero-day (Microsoft, 8 Apr) as Behavior	Source; Behavior	[13][31]
T1134.001	Token Impersonation/Theft	Stealth, Privilege Escalation	AA25-050A	Source	[13]

Id	Name	Tactic (v20.0)	Where it appears in the 2025 record	Basis	Source
T1484.001	Group Policy Modification	Defense Impairment, Privilege Escalation	Microsoft's SharePoint report (Warlock through Group Policy); AA25-071A; AA23-352A update; C0058 record	Source	[63][23][49][134]
T1006	Direct Volume Access	Stealth	AA25-071A	Source	[23]
T1027	Obfuscated Files or Information	Stealth	AA25-141B	Source	[43]
T1027.002	Software Packing	Stealth	C0058 record	Source	[134]
T1027.010	Command Obfuscation	Stealth	C0058 record	Source	[134]
T1036	Masquerading	Stealth	AA25-141B; C0059 record	Source	[43][134]
T1036.005	Match Legitimate Resource Name or Location	Stealth	AA25-203A	Source	[69]
T1070.009	Clear Persistence	Stealth	AA25-239A	Source	[85]
T1140	Deobfuscate/Decode Files or Information	Stealth	AA25-141B; C0058 record	Source	[43][134]
T1218.011	Rundll32	Stealth	AA25-203A	Source	[69]
T1564.012	File/Path Exclusions	Stealth	AA25-071A	Source	[23]
T1620	Reflective Code Loading	Stealth	Microsoft's SharePoint report; C0058 record	Source	[63][134]
T1684.001	Impersonation	Stealth	Printed as T1656 in the AA23-320A update (help-desk impersonation); C0059 record	Source	[72][132][134]
T1112	Modify Registry	Defense Impairment, Persistence	C0058 record	Source	[134]
T1553.004	Install Root Certificate	Defense Impairment	ApolloShadow installs trusted root certificates (Microsoft, 31 Jul)	Behavior	[73]
T1599	Network Boundary Bridging	Defense Impairment	AA25-239A	Source	[85]
T1685	Disable or Modify Tools	Defense Impairment	Printed as T1562.001 in AA25-050A, the AA23-352A update and Microsoft's SharePoint report; printed as T1685 on AA25-071A's live page and in the C0058 record	Source	[13][49][63][23][134][132]
T1685.005	Clear Windows Event Logs	Defense Impairment	Printed as T1070.001 in the AA23-352A update	Source	[49][132]

Id	Name	Tactic (v20.0)	Where it appears in the 2025 record	Basis	Source
T1686	Disable or Modify System Firewall	Defense Impairment	Printed as T1562.004 in AA25-239A	Source	[85][132]
T1003	OS Credential Dumping	Credential Access	AA25-050A	Source	[13]
T1003.001	LSASS Memory	Credential Access	Microsoft's SharePoint report; AA25-071A; C0058 record	Source	[63][23][134]
T1003.003	NTDS	Credential Access	AA25-141A	Source	[44]
T1040	Network Sniffing	Credential Access, Discovery	AA25-239A	Source	[85]
T1056.001	Keylogging	Collection, Credential Access	AA25-203A	Source	[69]
T1110.002	Password Cracking	Credential Access	AA25-239A	Source	[85]
T1110.003	Password Spraying	Credential Access	AA25-141A; AA24-109A update	Source	[44][120]
T1187	Forced Authentication	Credential Access	AA25-141A	Source	[44]
T1528	Steal Application Access Token	Credential Access	UNC6395's stolen Drift OAuth tokens (Aug)	Inferred	[78]
T1539	Steal Web Session Cookie	Credential Access	AA23-320A update table	Source	[72]
T1552.001	Credentials In Files	Credential Access	C0058 record; UNC6395's search of exported data for keys and passwords as Inferred	Source; Inferred	[134][78]
T1555.003	Credentials from Web Browsers	Credential Access	AA25-203A	Source	[69]
T1557	Adversary-in-the-Middle	Credential Access, Collection	Secret Blizzard's ISP-level position in Moscow (Microsoft, 31 Jul)	Behavior	[73]
T1558	Steal or Forge Kerberos Tickets	Credential Access	AA25-071A	Source	[23]
T1558.003	Kerberoasting	Credential Access	AA25-203A	Source	[69]
T1606	Forge Web Credentials	Credential Access	AA23-320A update table	Source	[72]
T1621	Multi-Factor Authentication Request Generation	Credential Access	AA23-320A update table	Source	[72]
T1012	Query Registry	Discovery	AA25-141B	Source	[43]
T1033	System Owner/User Discovery	Discovery	C0058 record	Source	[134]

Id	Name	Tactic (v20.0)	Where it appears in the 2025 record	Basis	Source
T1082	System Information Discovery	Discovery	C0058 record	Source	[134]
T1083	File and Directory Discovery	Discovery	C0058 and C0059 records	Source	[134]
T1217	Browser Information Discovery	Discovery	AA25-141B	Source	[43]
T1482	Domain Trust Discovery	Discovery	AA24-109A update	Source	[120]
T1021.001	Remote Desktop Protocol	Lateral Movement	AA25-203A	Source	[69]
T1021.007	Cloud Services	Lateral Movement	AA23-320A update table	Source	[72]
T1550.002	Pass the Hash	Lateral Movement	AA24-109A update	Source	[120]
T1570	Lateral Tool Transfer	Lateral Movement	Microsoft's SharePoint report; C0058 record	Source	[63][134]
T1005	Data from Local System	Collection	C0058 record	Source	[134]
T1074.001	Local Data Staging	Collection	C0058 record	Source	[134]
T1114	Email Collection	Collection	AA23-320A update	Source	[72]
T1114.002	Remote Email Collection	Collection	AA25-141A; UNC6395's reads of Drift-integrated Workspace mail (9 Aug) as Behavior	Source; Behavior	[44][78]
T1119	Automated Collection	Collection	AA25-141B; C0058 record	Source	[43][134]
T1125	Video Capture	Collection	AA25-141A (IP cameras at border crossings)	Source	[44]
T1213.004	Customer Relationship Management Software	Collection	C0059 record; UNC6395's Salesforce exports (Aug) as Behavior	Source; Behavior	[134][78]
T1530	Data from Cloud Storage	Collection	AA23-320A update and AA25-203A tables	Source	[72][69]
T1602.001	SNMP (MIB Dump)	Collection	AA25-239A; Static Tundra's SNMP abuse (FBI, 20 Aug) as Behavior	Source; Behavior	[85][82]
T1602.002	Network Device Configuration Dump	Collection	AA25-239A; Static Tundra's configuration collection (FBI and Talos, 20 Aug) as Behavior	Source; Behavior	[85][82][81]
T1071.001	Web Protocols	Command and Control	AA25-141B; C0058 record	Source	[43][134]
T1090	Proxy	Command and Control	AA23-320A update; C0058 and C0059 records	Source	[72][134]

Id	Name	Tactic (v20.0)	Where it appears in the 2025 record	Basis	Source
T1090.003	Multi-hop Proxy	Command and Control	AA25-239A; AA25-141A; C0059 record	Source	[85][44][134]
T1105	Ingress Tool Transfer	Command and Control	AA25-141B; C0058 record	Source	[43][134]
T1219	Remote Access Tools	Command and Control	AA25-071A, AA25-203A and AA23-320A update	Source	[23][69][72]
T1572	Protocol Tunneling	Command and Control	AA25-239A; C0058 record	Source	[85][134]
T1020	Automated Exfiltration	Exfiltration	C0059 record	Source	[134]
T1041	Exfiltration Over C2 Channel	Exfiltration	C0058 record	Source	[134]
T1048	Exfiltration Over Alternative Protocol	Exfiltration	AA25-203A	Source	[69]
T1048.003	Exfiltration Over Unencrypted Non-C2 Protocol	Exfiltration	AA25-239A	Source	[85]
T1537	Transfer Data to Cloud Account	Exfiltration	AA24-109A update	Source	[120]
T1567	Exfiltration Over Web Service	Exfiltration	AA23-320A update; C0059 record	Source	[72][134]
T1567.002	Exfiltration to Cloud Storage	Exfiltration	AA25-071A, AA25-203A, AA23-320A update and AA24-109A update	Source	[23][69][72][120]
T1485	Data Destruction	Impact	Storm-0501 destroys cloud data (Microsoft, 27 Aug); PathWiper (Talos, 5 Jun)	Behavior	[87][50]
T1486	Data Encrypted for Impact	Impact	AA25-050A, AA25-071A, AA25-203A, AA23-320A update, AA23-352A update and AA24-109A update; Microsoft's SharePoint report (Warlock); C0058 record	Source	[13][23][69][72][49][120][63][134]
T1489	Service Stop	Impact	AA25-071A	Source	[23]
T1490	Inhibit System Recovery	Impact	AA25-050A, AA25-071A and AA24-109A update; Storm-0501 destroys backups as Behavior	Source; Behavior	[13][23][120][87]
T1529	System Shutdown/Reboot	Impact	AA25-071A	Source	[23]

Id	Name	Tactic (v20.0)	Where it appears in the 2025 record	Basis	Source
T1657	Financial Theft	Impact	AA25-071A, AA25-203A and AA23-352A update; C0058 record; the Bybit theft (FBI, 26 Feb) as Behavior	Source; Behavior	[23][69][49][134][14]

Ids the record mentions but this study leaves out. AA23-320A's table prints the Mobile ids T1660 Phishing and T1451 SIM Card Swap; they are absent from the library's Enterprise data and have no technique page (T1451 appears in the library only as `/mitre/f3/T1451.md`), so they are not in the table or the layer (Confirmed [72]; Demonstrated [137]). AA24-109A's live table prints T1604, which is not an Enterprise technique in the library's data and is left out (Confirmed [120]; Demonstrated [137]). AA25-141B files T1106 Native API under Exfiltration; this study shows it under the Execution tactic the library's v20.0 data gives it (Confirmed [43]; Demonstrated [133]). AA25-239A maps 42 unique techniques; the table binds the ids the research recorded from it, so the advisory's remaining ids are not bound (Confirmed [85]). The GTIG reports on Oracle EBS, UNC6040 and Drift, Talos's PathWiper and Static Tundra reports, and Microsoft's Secret Blizzard and Storm-0501 reports print no ATT&CK ids, which is why their rows are Behavior or Inferred (Confirmed [80][56][78][50][81][73][87]).

ATT&CK for ICS techniques

Id	Name	Tactic (v20.0)	Where it appears in the 2025 record	Basis	Source
T0883	Internet Accessible Device	Initial Access	Minimally secured internet-facing VNC used to reach OT (AA25-343A)	Behavior	[126]
T0886	Remote Services	Initial Access, Lateral Movement	VNC sessions into OT environments (AA25-343A)	Behavior	[126]
T0879	Damage to Property	Impact	Impacts including physical damage (AA25-343A)	Behavior	[126]

The library carries these ids in `data/attack/ics/technique_profiles.jsonl` but has no generated ATT&CK for ICS pages, so they are not linked (Demonstrated [139]). The 6 May CISA alert and the Static Tundra reports describe interest in, or targeting of, ICS without naming an ICS behavior precise enough to bind, so they add no row (Confirmed [37][82]; Inferred for the decision). The home study for the industrial record, the ICS attacks and advisories study, carries the fuller ICS binding.

ATT&CK groups, software and campaigns

Object	Id and library page	Tie to the 2025 record	Source
Salt Typhoon	G1045	Treasury sanctions (17 Jan); AA25-239A (27 Aug)	[4][85][86]
HAFNIUM	G0125	Silk Typhoon alias; Microsoft (5 Mar); Xu Zewei (8 Jul)	[19][67][134]
Threat Group-3390	G0027	APT27 and Linen Typhoon aliases; DOJ charges (5 Mar); SharePoint (Jul); C0058	[17][63][66][134]
ZIRCONIUM	G0128	Violet Typhoon alias; SharePoint (Jul); C0058	[63][66][134]
UNC3886	G1048	Juniper MX backdoors (Mandiant, 11 Mar)	[22]
APT28	G0007	GRU unit 26165; AA25-141A (21 May)	[44]
Turla	G0010	Secret Blizzard alias; ApolloShadow (31 Jul)	[73][134]
Dragonfly	G0035	Berserk Bear and Energetic Bear aliases; Static Tundra as a sub-cluster (FBI and Talos, 20 Aug); binding Inferred	[82][81][134]
Scattered Spider	G1015	AA23-320A update (29 Jul); Thalha Jubair complaint (18 Sep)	[72][92]
ShinyHunters	G1057	UNC6240 alias; extortion after UNC6040's thefts	[56][134]
Storm-0501	G1053	Cloud-based ransomware (27 Aug)	[87]
Medusa Group	G1051	AA25-071A (12 Mar); Storm-1175 as a Medusa affiliate (6 Oct)	[23][94]
Play	G1040	AA23-352A update (4 Jun)	[49]
Akira	G1024	AA24-109A update (13 Nov); IC3's top variant	[120][131]
INC Ransom	G1032	IC3's INC/Lynx/Sinobi entry among the top variants	[131]
SharePoint ToolShell Exploitation	C0058	July 2025 SharePoint wave	[66][63]
Salesforce Data Exfiltration	C0059	UNC6040's vishing and data theft, October 2024 to September 2025	[134][56][90]
RedPenguin	C0056	UNC3886's Juniper MX backdoors (Mandiant, 11 Mar)	[22][134]
Anthropic AI-orchestrated Campaign	C0062	Detected mid-September 2025; disclosed 13 Nov	[103][134]
2025 Poland Wiper Attacks	C0063	Destructive attacks on Polish energy infrastructure, December 2025; told in the ICS and Russia home studies	[134]
ArcaneDoor	C0046	The prior campaign of the actor Cisco ties to the 2025 ASA wave; its record ends in April 2024, so the 2025 wave is outside it	[101][98][134]
DRYHOOK	S9013	Ivanti CVE-2025-0282 (Jan)	[1]
PHASEJAM	S9014	Ivanti CVE-2025-0282 (Jan)	[1]

Object	Id and library page	Tie to the 2025 record	Source
SPAWNCHIMERA	S9024	The SPAWN family named in both Ivanti reports; the binding to this member is Inferred	[1][28][134]
TRAILBLAZE	S9012	Ivanti CVE-2025-22457 (Apr)	[28]
BRUSHFIRE	S9011	Ivanti CVE-2025-22457 (Apr)	[28]
BRICKSTORM	S9015	AR25-338A (4 Dec)	[124]
Impacket	S0357	C0058 software	[66]
Mimikatz	S0002	C0058 software	[66]
ngrok	S0508	C0058 software	[66]
PsExec	S0029	C0058 software	[66]
Line Dancer	S1186	ArcaneDoor's 2024 tool, named for the actor's history; no 2025 source names it	[101][134]
Line Runner	S1188	ArcaneDoor's 2024 tool, named for the actor's history; no 2025 source names it	[101][134]
HermeticWiper	S0697	Talos compares PathWiper to it (5 Jun)	[50]
Clop	S0611	The CL0P brand on the Oracle EBS extortion emails; no tie to the ransomware itself (Inferred)	[80]
Medusa Ransomware	S1244	AA25-071A; Medusa deployed after GoAnywhere access	[23][94]
Playcrypt	S1162	AA23-352A update	[49]
Akira	S1129	AA24-109A update	[120]
Lumma Stealer	S1213	Disruption and AA25-141B (21 May)	[41][42][43]
Bumblebee	S1039	Operation Endgame (May)	[45]
Latrodectus	S1160	Operation Endgame (May)	[45]
QakBot	S0650	Operation Endgame (May)	[45]
TrickBot	S0266	Operation Endgame (May)	[45]
Royal	S1073	BlackSuit (Royal) disruption (11 Aug, per IC3)	[131]
Conti	S0575	Proceeds through Garantex (OFAC, 14 Aug)	[77]
Black Basta	S1070	Proceeds through Garantex (OFAC, 14 Aug)	[77]
Netwalker	S0457	Proceeds through Garantex (OFAC, 14 Aug)	[77]
LockBit 3.0	S1202	LockBit proceeds through Garantex; Zservers (11 Feb); IC3's top variants (version binding Inferred)	[77][12][131]
Qilin	S1242	IC3's second most reported variant	[131]

Object	Id and library page	Tie to the 2025 record	Source
INC Ransomware	S1139	IC3's INC/Lynx/Sinobi entry	[131]
RansomHub	S1212	IC3's top variants	[131]
Shai-Hulud	S9008	The npm worm (Sep) and its renewed variant (Nov)	[96][122]
LAMEHUG	S9035	PROMPTSTEAL alias; GTIG (5 Nov)	[116][134]

That is 53 rows, of which 45 bind a 2025 event directly and 8 (C0046, S1186, S1188, S0697, S0611, S0575, S0457 and S1070) are named for context or money flows. No ATT&CK group or software object in the library covers Flax Typhoon, UNC5221, UNC6040, UNC6395, Storm-2603, Storm-1175, Storm-2460, UAT-9686, RomCom, TraderTraitor, FIN11, Interlock, Ghost or Cring, DragonForce, Warlock, PathWiper, ApolloShadow, HEADLACE, MASEPIE, RayInitiator, LINE VIPER, AquaShell, DanaBot, HijackLoader, WarmCookie, SafePay or the 8Base and Phobos operation, so they stay unlinked (Demonstrated [134]). UNC6040 and Storm-2603 appear only in the descriptions of C0059 and C0058, and UNC5221 only in that of the earlier campaign C0029 Cutting Edge (December 2023 to February 2024) (Demonstrated [134]). G0032 Lazarus Group is deliberately not bound to Bybit, because the FBI's attribution names TraderTraitor and North Korea, not Lazarus (Confirmed [14]; Inferred for the decision). The home study for ToolShell does not yet cite C0058 or carry a Navigator layer; that gap is the home study's to close (Demonstrated [138]).

CWE and CAPEC

Weakness	CVEs in this record	CAPEC in the library	Source
CWE-121 Stack-based Buffer Overflow, CWE-787 Out-of-bounds Write	CVE-2025-0282 (Ivanti; NVD)	None in the library for either	[128][135]
CWE-120 Buffer Copy without Checking Size of Input	CVE-2025-20333 (Cisco ASA)	CAPEC-100 Overflow Buffers, one of 13 the library relates; the pick is this study's (Inferred)	[100][128][135]
CWE-862 Missing Authorization	CVE-2025-20362 (Cisco ASA)	The library relates only CAPEC-665, which does not fit, so none is bound	[128][135]
CWE-125 Out-of-bounds Read, CWE-908 Use of Uninitialized Resource	CVE-2025-5777 (Citrix NetScaler)	CAPEC-540 Overread Buffers for CWE-125; none for CWE-908	[128][135]
CWE-502 Deserialization of Untrusted Data	CVE-2025-53770 (SharePoint), CVE-2025-59287 (WSUS), CVE-2025-10035 (GoAnywhere, with CWE-77), CVE-2025-24813 (Tomcat, with CWE-44 and CWE-706)	CAPEC-586 Object Injection	[65][114][135]
CWE-94 Improper Control of Generation of Code	CVE-2025-49704 (SharePoint)	CAPEC-242 Code Injection, one of three the library relates	[65][135]
CWE-287 Improper Authentication	CVE-2025-49706 and CVE-2025-53771 (SharePoint); CVE-2025-61882 (Oracle EBS; CISA ADP and NVD); CVE-2025-53786 (Exchange hybrid, per ED 25-02)	CAPEC-115 Authentication Bypass, one of ten the library relates; the pick is this study's (Inferred)	[65][107][108][76][135]
CWE-77 Improper Neutralization of Special Elements used in a Command	CVE-2025-10035 (GoAnywhere, with CWE-502)	CAPEC-248 Command Injection (Inferred fit)	[114][135]
CWE-434 Unrestricted Upload of File with Dangerous Type	CVE-2025-31324 (SAP NetWeaver)	The library relates CAPEC-1, which is not a clear fit, so none is bound	[114][2][135]
CWE-306 Missing Authentication for Critical Functionality	CVE-2025-32433 (Erlang/OTP SSH)	None of the five CAPEC the library relates (CAPEC-12, 36, 62, 166, 216) is a clear fit, so none is bound	[2][135]

Weakness	CVEs in this record	CAPEC in the library	Source
CWE-506 Embedded Malicious Code	CVE-2025-30066 (tj-actions), CVE-2025-30154 (reviewdog)	CAPEC-442 Infected Software, which the library relates to CWE-506 and pairs with T1195.001 and T1195.002	[26][135]
CWE-44, CWE-706	CVE-2025-24813 (Tomcat, with CWE-502)	Bound through CWE-502 above	[114]

Across all 245 KEV additions of 2025 the most common CWEs were CWE-78 (18), CWE-502 (15), CWE-22 (13), CWE-787 (11) and CWE-416 (11); the library relates no CAPEC to CWE-787 or CWE-416 (Demonstrated [2][135]).

The library pairs CAPEC with many of this study's techniques; the rows below bear on the year's central behaviors (Demonstrated [133][135]):

Technique	CAPEC in the library	2025 behavior
T1505.003 Web Shell	CAPEC-650 Upload a Web Shell to a Web Server	SharePoint ToolShell; Ghost
T1195.001 Compromise Software Dependencies and Development Tools	CAPEC-538 Open-Source Library Manipulation, CAPEC-695 Repo Jacking, CAPEC-442 Infected Software	tj-actions, Nx, Shai-Hulud
T1195.002 Compromise Software Supply Chain	CAPEC-186 Malicious Software Update, CAPEC-442 Infected Software	Amazon Q Developer v1.84
T1528 Steal Application Access Token, T1539 Steal Web Session Cookie	CAPEC-21 Exploitation of Trusted Identifiers	Salesloft Drift tokens; Scattered Spider
T1606 Forge Web Credentials	CAPEC-196 Session Credential Falsification through Forging	Scattered Spider
T1566 Phishing, T1598 Phishing for Information	CAPEC-98 Phishing	Medusa; UNC6040 voice phishing
T1078 Valid Accounts	CAPEC-560 Use of Known Domain Credentials	Play; Scattered Spider
T1542.001 System Firmware	CAPEC-532 Altered Installed BIOS	Cisco ASA read-only memory manipulation (fit Inferred)
T1110.003 Password Spraying	CAPEC-565 Password Spraying	APT28; Akira
T1133 External Remote Services, T1114.002 Remote Email Collection	CAPEC-555 Remote Services with Stolen Credentials	Akira's VPN access; APT28's mail collection
T1557 Adversary-in-the-Middle	CAPEC-94 Adversary in the Middle (AiTM)	Secret Blizzard in Moscow

The library has no generated CWE pages; the CWE Reference and CAPEC Reference cover the classes.

D3FEND countermeasures

Countermeasure	The library's mappings to this study's techniques (technique_to_d3fend.json)	2025 guidance it matches	Source
Multi-factor Authentication (D3-MFA)	T1110.003, T1528	Phishing-resistant MFA in AA23-320A and on GitHub and npm (Shai-Hulud alert)	[136][72][96]
Credential Rotation (D3-CRO)	T1110.003, T1528	Rotating Drift integration tokens; rotating secrets exposed by tj-actions and Shai-Hulud	[136][78][25][96]
Credential Revocation (D3-CR)	T1110.003, T1528	Drift tokens revoked 20 Aug; credentials, API keys and certificates revoked after Ivanti compromise	[136][78][1]
Authentication Cache Invalidation (D3-ANCI)	T1110.003, T1528	Ending sessions held with stolen tokens (pairing Inferred)	[136][78]
Credential Hardening (D3-CH)	T1110.003, T1528	Type 8 passwords on network devices (AA25-239A); no plaintext credentials (AA25-212A)	[136][85][74]
Token Binding (D3-TB)	T1528	Integration tokens usable only from expected IPs (GTIG's IP restrictions; pairing Inferred)	[136][78]
Access Modeling (D3-AM)	T1078	Knowing what each connected app and service account may reach (pairing Inferred)	[136][78]
User Account Permissions (D3-UAP)	T1078	Least-scope connected apps (GTIG); scoped CI tokens (AWS)	[136][78][71]
Firmware Verification (D3-FV)	T1542.001	Firmware integrity checks (AA25-239A); ED 25-03's core dumps and hard reset	[136][85][98]
Firmware Behavior Analysis (D3-FBA)	T1542.001	Detecting ROM persistence on ASA devices (pairing Inferred)	[136][98]
Software Inventory (D3-SWI)	T1072, T1195.001, T1195.002, T1490, T1542.001	F5 inventories under ED 26-01; knowing which actions and packages builds pull	[136][111][25]
Software Update (D3-SU)	T1072, T1195.001, T1195.002, T1490, T1542.001	Minimum fixed versions for Cisco ASA (CISA, 12 Nov); F5 patch deadlines	[136][119][111]
Asset Vulnerability Enumeration (D3-AVE)	T1072, T1195.001, T1195.002, T1490, T1542.001	Finding end-of-life devices like those Static Tundra exploited (pairing Inferred)	[136][82]
Restore Software (D3-RS)	T1072, T1195.001, T1195.002, T1490, T1542.001	Pinning to npm releases before 16 Sep; Ivanti factory reset	[136][96][1]

Countermeasure	The library's mappings to this study's techniques (`technique_to_d3fend.json`)	2025 guidance it matches	Source
Restore Configuration (D3-RC)	T1490	Configuration baselines on network devices (AA25-239A)	[136][85]
File Integrity Monitoring (D3-FIM)	T1072, T1486, T1505.003, T1552.001	Web shell and tampered-file detection on SharePoint and Ivanti	[136][63][1]
Decoy File (D3-DF)	T1072, T1486, T1505.003, T1552.001	Early warning of encryption and credential-file reads (pairing Inferred)	[136][23]
Restore File (D3-RF)	T1072, T1486, T1505.003, T1552.001	Offline immutable backups (AA23-320A)	[136][72]
Executable Allowlisting (D3-EAL)	T1505.003	Allowlisting of remote access tools (AA23-320A; pairing Inferred)	[136][72]
Inbound Traffic Filtering (D3-ITF)	T1190	Default-deny access lists on the management plane (AA25-239A)	[136][85]
Network Traffic Filtering (D3-NTF)	T1110.003, T1190, T1199, T1219, T1557, T1567.002	Out-of-band management networks (AA25-239A); IP restrictions on connected apps (GTIG)	[136][85][78]
Outbound Traffic Filtering (D3-OTF)	T1219, T1567.002	Limiting egress for remote access tools and cloud exfiltration (ransomware advisories; pairing Inferred)	[136][23][69]
Session Termination (D3-ST)	T1133, T1199	Cutting a trusted partner's session on suspicion (Drift, 5CA; pairing Inferred)	[136][78][105]

Gaps in the library's map: it binds no D3FEND countermeasure to T1566.004 or T1598.004 Spearphishing Voice, T1684.001 Impersonation, T1602.001 and T1602.002, T1530 Data from Cloud Storage, T1556.006 Multi-Factor Authentication, T1553.004 Install Root Certificate or T1485 Data Destruction, though help-desk voice phishing, network-device configuration theft and cloud data destruction were the year's defining behaviors (Demonstrated [136]; Inferred for the reading). The library's D3FEND Reference covers the countermeasures.

Navigator layers

The study's Enterprise techniques are saved as an ATT&CK Navigator layer, navigator/library-layers/chronicle-2025.json, and the three ICS rows as navigator/case-studies/chronicle-2025-ics.json, both listed on the Navigator layers page. Open the Enterprise layer in the ATT&CK Navigator. Both are pinned to ATT&CK v20 and are checked against the library's technique profiles by the repository's `scripts/validate_navigator.py` gate. Scores show the basis, not severity: 100 where an opened source or the ATT&CK record prints the id, 70 where the source describes the behavior and this study assigns the id, and 40 for an Inferred mapping. Each entry's comment names the event, the date and the source numbers above, and each technique is shown under every tactic it has in v20.0.

Cross-cutting themes

- **The edge was still the front door, and remediation lagged the exploit (Inferred).** Ivanti twice, Fortinet, Cisco ASA, Citrix, SonicWall's cloud backups, F5 and Cisco AsyncOS fell during the year, and CISA found organizations below Cisco's fixed versions two months after its directive (Confirmed [1][28][6][98][2][91][79][125][119]). See Edge Device Security.
- **Trust between services replaced the password as the prize (Inferred).** OAuth tokens (Drift), client secrets (Commvault), a connected app (UNC6040), a vendor's help desk (5CA) and paid insiders (Coinbase) gave access that no exploit was needed for (Confirmed [78][46][56][105][39]). See Cloud Attacks and Identity Security.
- **People were socially engineered at scale by voice (Inferred).** Help-desk impersonation, call-centre vishing and AI-generated voices of officials appear in the year's advisories (Confirmed [72][90][127]).
- **The build pipeline was an identity system (Inferred).** The 2025 CI compromises recorded here moved through tokens and credentials: secrets in a build log, an over-scoped token in a CodeBuild configuration, a phished maintainer's npm account (Confirmed [25][71][96]; Reported [89]). See Supply Chain Security.
- **Crime and state used the same flaws in the same weeks (Inferred).** ToolShell and Ivanti CVE-2025-0282 each drew state actors and carry KEV's known-ransomware flag, and Microsoft saw the China-based Storm-2603 deploy Warlock through ToolShell; GoAnywhere drew a Medusa affiliate (Confirmed [63][1][19][2][94]). See Threat Actors.
- **Enforcement went after the plumbing (Inferred).** Bulletproof hosts, a crypto exchange and its successor, domains and command servers were the targets as often as people (Confirmed [12][60][121][77][41][45]). See Ransomware Defense and Malware Families.

What is overstated and what is understated

- **Overstated: "Salesforce was breached."** GTIG says the Drift token theft was not a vulnerability in the Salesforce platform, and UNC6040 relied on staff authorizing a modified app (Confirmed [78][56]; Inferred for the reading).
- **Overstated: the F5 theft as a supply chain compromise.** F5, NCC Group and IOActive report no change to F5's build or release pipelines; the risk is future exploitation of stolen knowledge (Confirmed [112]; Inferred [112]).

- **Overstated: Bybit as a Lazarus operation.** The FBI names North Korea and TraderTraitor, not Lazarus; Chainalysis's "largest digital heist in crypto history" is its own ranking (Confirmed [14]; Reported [15]).
- **Overstated: autonomous AI attacks.** Anthropic reports that the AI performed most of the tactical work but that the campaign succeeded in a small number of cases and the AI at times fabricated credentials; GTIG describes the first malware that calls an LLM while running, not a wave of it (Confirmed [103][116]; Inferred for the reading).
- **Overstated: firm national labels.** CISA names no state for the Cisco ASA campaign or for F5, Microsoft gives only moderate confidence that Storm-2603 is China-based, and the DOJ's alias list for APT27 disagrees with ATT&CK's and Mandiant's (Confirmed [98][111][63][17]).
- **Overstated: first-disclosure scope.** SonicWall's "fewer than 5%" became all cloud-backup customers six weeks later, and this study uses CISA's "over 500" npm packages as of 23 September rather than any later count (Confirmed [91][96]).
- **Understated: old vulnerabilities.** 94 of the 245 KEV additions of 2025 carry pre-2025 CVE ids and 23 pre-2020 ids; Salt Typhoon's backbone campaign used no zero-days; Static Tundra exploited a 2018 bug; Ghost entered through flaws from 2009 to 2021 (Demonstrated [2]; Confirmed [85][81][13]).
- **Understated: incident counts.** The NCSC says its data understates incidents because reporting is often not mandatory, and IC3's US$32 million excludes downtime and remediation (Confirmed [110][131]).
- **Understated: incomplete patching.** CISA found Cisco ASA owners who believed they were patched and were not (Confirmed [119]).
- **Understated: insiders and vendors.** The Coinbase and Discord cases turned on people outside the company's own staff with access to customer data (Confirmed [39][105]; Inferred for the reading).
- **Understated: KEV's ransomware flag as history.** The flag is current, not the state at listing, so the 31 counted here can change as CISA updates entries (Confirmed [2]; Inferred for the caution).

Discrepancies in the record

- **APT27's aliases.** The DOJ release lists Threat Group 3390, Emissary Panda, UNC 5221 and Silk Typhoon as APT27 aliases; ATT&CK puts Silk Typhoon on G0125 HAFNIUM, as Microsoft does, and Mandiant tracks UNC5221 separately (Confirmed [17][19][1]; Demonstrated [134]).
- **Salt Typhoon's aliases.** Live ATT&CK lists OPERATOR PANDA, RedMike, GhostEmperor and UNC5807 as associated groups of G1045; the library's `groups.jsonl` lists only "Salt Typhoon" (Confirmed [86]; Demonstrated [134]).
- **AA25-239A's sealers.** One reading counts agencies of 13 countries, another 23 agencies; the two counts measure different things (Confirmed [85]).
- **The IT-worker counts.** The DOJ release says 29 suspected laptop farms in 16 states in one place and 21 premises in 14 states in another, and gives both 17 domains and 21 websites (Confirmed [59]).
- **Lumma's scale.** Microsoft counts over 394,000 infected Windows computers in two months and about 2,300 domains under its civil action; the DOJ counts five seized domains and cites at least 1.7 million instances of data theft. They count different things (Confirmed [41][42]).
- **The tj-actions window.** CISA gives an affected window of 12 to 15 March; StepSecurity dates the incident's start to about 16:00 UTC on 14 March (Confirmed [25][24]).

- **Oracle EBS's start.** GTIG gives suspicious activity from 10 July and possible zero-day exploitation from 9 August (Confirmed [80]).
- **AA25-022A's date.** The advisory's release date is 22 January; the page opened is dated 31 January (Confirmed [9]).
- **ED 26-01's deadlines.** One reading gives patch deadlines of 22 and 31 October; another gives 22 October and inventory reports by 29 October and 3 December (Confirmed [111]).
- **Integrity Technology Group's date.** The 17 January Treasury release relays the 3 January designation; the 3 January release is the primary (Confirmed [3][4]).
- **GTIG's 2024 count.** The review published on 29 April counted 75 zero-days in 2024; the 2025 review revises it to 78 (Confirmed [35][130]).
- **AA25-141B's tactics.** The advisory files T1106 Native API under Exfiltration; ATT&CK gives Execution (Confirmed [43]; Demonstrated [133]).
- **AA25-071A's live tables.** The March 2025 advisory now prints ATT&CK v20 names after its August 2026 update (Confirmed [23]).
- **The ArcaneDoor window.** ATT&CK's C0046 ends in April 2024, while Talos ties the 2025 ASA activity to the same actor (Confirmed [101]; Demonstrated [134]).
- **CVE-2025-53771.** Its NVD record has no KEV date, though MSRC's guidance covers it with CVE-2025-53770 (Confirmed [65][64]).

Sources

All sources were opened on 11 November 2026. "Primary" means the organization that published the fact; grades apply to the source as used here. Addresses shown as code rather than as links refuse automated link checkers (the sec.gov filings); copy them into a browser to open them.

#	Source	URL	Opened	Grade
1	Mandiant (Google Cloud), Ivanti Connect Secure VPN zero-day exploitation (CVE-2025-0282), Jan 2025, updated 17 Jan 2025	cloud.google.com	2026-11-11	Confirmed
2	CISA, Known Exploited Vulnerabilities catalog (JSON feed, catalog version 2026.11.10)	cisa.gov	2026-11-11	Confirmed
3	US Treasury, sanctions on Integrity Technology Group (Flax Typhoon), 3 Jan 2025	home.treasury.gov	2026-11-11	Confirmed
4	US Treasury, sanctions on Sichuan Juxinhe Network Technology and Yin Kecheng, 17 Jan 2025	home.treasury.gov	2026-11-11	Confirmed
5	Conduent, Form 8-K (Item 1.05), filed 14 Apr 2025	`https://www.sec.gov/Archives/edgar/data/1677703/000167770325000067/cndt-20250409.htm`	2026-11-11	Confirmed
6	Fortinet PSIRT, FG-IR-24-535 (CVE-2024-55591), revision of 14 Jan 2025	fortiguard.fortinet.com	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
7	The White House (archive), Executive Order 14144 on strengthening and promoting innovation in the nation's cybersecurity, 16 Jan 2025	bidenwhitehouse.archives.gov	2026-11-11	Confirmed
8	Wiz Research, exposed DeepSeek database, 29 Jan 2025	wiz.io	2026-11-11	Confirmed
9	CISA and FBI, AA25-022A, Ivanti Cloud Service Appliance exploit chains, Jan 2025	cisa.gov	2026-11-11	Confirmed
10	Lee Enterprises, Form 8-K (Item 1.05), filed 18 Feb 2025	`https://www.sec.gov/Archives/edgar/data/58361/000162828025005855/lee-20250212.htm`	2026-11-11	Confirmed
11	US DOJ, Phobos ransomware affiliates arrested in coordinated international disruption, 10 Feb 2025	justice.gov	2026-11-11	Confirmed
12	US Treasury, sanctions on Zservers (with Australia and the UK), 11 Feb 2025	home.treasury.gov	2026-11-11	Confirmed
13	CISA, FBI and partners, AA25-050A, #StopRansomware: Ghost (Cring), 19 Feb 2025	cisa.gov	2026-11-11	Confirmed
14	FBI, PSA I-022625-PSA, North Korea responsible for US$1.5 billion Bybit hack, 26 Feb 2025	ic3.gov	2026-11-11	Confirmed
15	Chainalysis, Bybit exchange hack, February 2025	chainalysis.com	2026-11-11	Reported
16	Chainalysis, ransomware payments and victim extortion, 5 Feb 2025	chainalysis.com	2026-11-11	Reported
17	US DOJ, Justice Department charges 12 Chinese contract hackers and law enforcement officers, 5 Mar 2025	justice.gov	2026-11-11	Confirmed
18	US Treasury, sanctions on Zhou Shuai and Shanghai Heiying Information Technology, 5 Mar 2025	home.treasury.gov	2026-11-11	Confirmed
19	Microsoft Threat Intelligence, Silk Typhoon targeting IT supply chain, 5 Mar 2025	microsoft.com	2026-11-11	Confirmed
20	CISA, FBI warns of data extortion scam targeting corporate executives, 6 Mar 2025	cisa.gov	2026-11-11	Confirmed
21	US DOJ, Garantex cryptocurrency exchange disrupted in international operation, 7 Mar 2025	justice.gov	2026-11-11	Confirmed
22	Mandiant (Google Cloud), China-nexus espionage actor targets Juniper routers, 11 Mar 2025	cloud.google.com	2026-11-11	Confirmed
23	FBI and CISA with MS-ISAC, AA25-071A, #StopRansomware: Medusa, 12 Mar 2025; updated 18 Aug 2026 with HHS as co-sealer	cisa.gov	2026-11-11	Confirmed
24	StepSecurity, Harden-Runner detection: tj-actions/changed-files action is compromised, Mar 2025	stepsecurity.io	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
25	CISA, Supply chain compromise of third-party tj-actions/changed-files (CVE-2025-30066) and reviewdog/action-setup (CVE-2025-30154), 18 Mar 2025, updated 19 and 26 Mar	cisa.gov	2026-11-11	Confirmed
26	CVE Program, CVE-2025-30066 record (with CVE-2025-30154)	cve.org	2026-11-11	Confirmed
27	Kaspersky Securelist, Operation ForumTroll, 25 Mar 2025	securelist.com	2026-11-11	Confirmed
28	Mandiant (Google Cloud), China-nexus actor exploiting critical Ivanti Connect Secure vulnerability (CVE-2025-22457), Apr 2025	cloud.google.com	2026-11-11	Confirmed
29	CISA, NSA, FBI and international partners release cybersecurity advisory on fast flux (AA25-093A), 3 Apr 2025	cisa.gov	2026-11-11	Confirmed
30	Sensata Technologies, Form 8-K (Item 1.05), Apr 2025	https://www.sec.gov/Archives/edgar/data/1477294/000147729425000047/st-20250406.htm	2026-11-11	Confirmed
31	Microsoft Threat Intelligence, Exploitation of CLFS zero-day leads to ransomware activity, 8 Apr 2025	microsoft.com	2026-11-11	Confirmed
32	DaVita, Form 8-K, Apr 2025	https://www.sec.gov/Archives/edgar/data/927066/000119312525079593/d948299d8k.htm	2026-11-11	Confirmed
33	CISA, Guidance on credential risks associated with potential legacy Oracle cloud compromise, 16 Apr 2025	cisa.gov	2026-11-11	Confirmed
34	Volexity, Phishing for codes: Russian threat actors target Microsoft 365 OAuth workflows, 22 Apr 2025	volexity.com	2026-11-11	Confirmed
35	Google GTIG, 2024 zero-day exploitation analysis, 29 Apr 2025	cloud.google.com	2026-11-11	Confirmed
36	Verizon, 2025 Data Breach Investigations Report release, 23 Apr 2025	verizon.com	2026-11-11	Reported
37	CISA, Unsophisticated cyber actors targeting operational technology, 6 May 2025	cisa.gov	2026-11-11	Confirmed
38	CISA, FBI, EPA and DOE, Primary mitigations to reduce cyber threats to operational technology, May 2025	cisa.gov	2026-11-11	Confirmed
39	Coinbase Global, Form 8-K (Item 1.05), filed 15 May 2025	https://www.sec.gov/Archives/edgar/data/1679788/000167978825000094/coin-20250514.htm	2026-11-11	Confirmed
40	Nucor, Form 8-K (Item 1.05), May 2025	https://www.sec.gov/Archives/edgar/data/73309/000119312525119311/d795264d8k.htm	2026-11-11	Confirmed
41	Microsoft On the Issues (Digital Crimes Unit), Microsoft leads global action against favored cybercrime tool, 21 May 2025	blogs.microsoft.com	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
42	US DOJ, Justice Department seizes domains behind major information-stealing malware operation, 21 May 2025	justice.gov	2026-11-11	Confirmed
43	FBI and CISA, AA25-141B, LummaC2 malware TTPs and IOCs, 21 May 2025	cisa.gov	2026-11-11	Confirmed
44	NSA, FBI, CISA and partners, AA25-141A, Russian GRU targeting Western logistics entities and technology companies, 21 May 2025	cisa.gov	2026-11-11	Confirmed
45	Europol, Operation Endgame strikes again: the ransomware kill chain broken at its source, May 2025	europol.europa.eu	2026-11-11	Confirmed
46	CISA, Advisory update on cyber threat activity targeting Commvault's SaaS cloud application (Metallic), 22 May 2025	cisa.gov	2026-11-11	Confirmed
47	US Treasury, sanctions on Funnull Technology, 29 May 2025	home.treasury.gov	2026-11-11	Confirmed
48	CISA, Updated guidance on Play ransomware, 4 Jun 2025	cisa.gov	2026-11-11	Confirmed
49	FBI, CISA and ASD's ACSC, AA23-352A, #StopRansomware: Play, updated 4 Jun 2025	cisa.gov	2026-11-11	Confirmed
50	Cisco Talos, PathWiper targets Ukraine, 5 Jun 2025	blog.talosintelligence.com	2026-11-11	Confirmed
51	United Natural Foods (UNFI), Form 8-K (Item 1.05), filed 26 Jun 2025	`https://www.sec.gov/Archives/edgar/data/1020859/000102085925000036/unfi-20250621.htm`	2026-11-11	Confirmed
52	Erie Indemnity, Form 8-K, Jun 2025	`https://www.sec.gov/Archives/edgar/data/922621/000092262125000023/erie-20250607.htm`	2026-11-11	Confirmed
53	The White House, Executive Order 14306, sustaining select efforts to strengthen the nation's cybersecurity, 6 Jun 2025	whitehouse.gov	2026-11-11	Confirmed
54	CISA, AA25-163A, ransomware actors exploit unpatched SimpleHelp RMM, 12 Jun 2025	cisa.gov	2026-11-11	Confirmed
55	Aflac, Form 8-K, filed 20 Jun 2025	`https://www.sec.gov/Archives/edgar/data/4977/000000497725000128/afl-20250620.htm`	2026-11-11	Confirmed
56	Google GTIG, voice phishing and data extortion (UNC6040), 4 Jun 2025, updated 5 Aug 2025	cloud.google.com	2026-11-11	Confirmed
57	Alaska Air Group, Form 8-K (Hawaiian Airlines), filed 27 Jun 2025	`https://www.sec.gov/Archives/edgar/data/766421/000076642125000023/alk-20250627.htm`	2026-11-11	Confirmed
58	CISA, FBI, DC3 and NSA, Iranian cyber actors may target vulnerable US networks and entities of interest, 30 Jun 2025	cisa.gov	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
59	US DOJ, coordinated nationwide actions to combat North Korean remote IT workers, 30 Jun 2025	justice.gov	2026-11-11	Confirmed
60	US Treasury, sanctions on Aeza Group, 1 Jul 2025	home.treasury.gov	2026-11-11	Confirmed
61	Ingram Micro Holding, Form 8-K, filed 7 Jul 2025	`https://www.sec.gov/Archives/edgar/data/1897762/000162828025034372/ingm-20250705.htm`	2026-11-11	Confirmed
62	UK National Crime Agency, Retail cyber attacks: NCA arrest four for attacks on M&S, Co-op and Harrods, 10 Jul 2025	nationalcrimeagency.gov.uk	2026-11-11	Confirmed
63	Microsoft Threat Intelligence, Disrupting active exploitation of on-premises SharePoint vulnerabilities, 22 Jul 2025, updated 23 Jul	microsoft.com	2026-11-11	Confirmed
64	MSRC, Customer guidance for SharePoint vulnerability CVE-2025-53770, 19 Jul 2025	microsoft.com	2026-11-11	Confirmed
65	NVD, CVE-2025-53770, CVE-2025-49704, CVE-2025-49706 and CVE-2025-53771 (API record for CVE-2025-53770 shown)	services.nvd.nist.gov	2026-11-11	Confirmed
66	MITRE ATT&CK, C0058 SharePoint ToolShell Exploitation (live page)	attack.mitre.org	2026-11-11	Confirmed
67	US DOJ, arrest of prolific Chinese state-sponsored contract hacker (Xu Zewei), 8 Jul 2025	justice.gov	2026-11-11	Confirmed
68	ESET Research (WeLiveSecurity), Update WinRAR tools now: RomCom and others exploiting zero-day vulnerability, 11 Aug 2025	welivesecurity.com	2026-11-11	Confirmed
69	FBI, CISA, HHS and MS-ISAC, AA25-203A, #StopRansomware: Interlock, 22 Jul 2025	cisa.gov	2026-11-11	Confirmed
70	UK government, UK to lead crackdown on cyber criminals with ransomware measures, 22 Jul 2025	gov.uk	2026-11-11	Confirmed
71	AWS, Security Bulletin AWS-2025-015 (Amazon Q Developer for VS Code, CVE-2025-8217), Jul 2025	aws.amazon.com	2026-11-11	Confirmed
72	FBI and CISA, AA23-320A, Scattered Spider, updated 29 Jul 2025	cisa.gov	2026-11-11	Confirmed
73	Microsoft Threat Intelligence, Frozen in transit: Secret Blizzard's AiTM campaign against diplomats, 31 Jul 2025	microsoft.com	2026-11-11	Confirmed
74	CISA and USCG, AA25-212A, findings from a proactive hunt at a US critical infrastructure organization, 31 Jul 2025	cisa.gov	2026-11-11	Confirmed
75	Anthropic, Detecting and countering misuse of AI: August 2025	anthropic.com	2026-11-11	Confirmed
76	CISA, Emergency Directive 25-02, Mitigate Microsoft Exchange vulnerability, 7 Aug 2025	cisa.gov	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
77	US Treasury, re-designation of Garantex and designation of Grinex, 14 Aug 2025	home.treasury.gov	2026-11-11	Confirmed
78	Google GTIG, data theft from Salesforce instances via Salesloft Drift (UNC6395), 26 Aug 2025, updated 28 Aug	cloud.google.com	2026-11-11	Confirmed
79	F5, Form 8-K (Item 1.05), filed 15 Oct 2025	`https://www.sec.gov/Archives/edgar/data/1048695/000104869525000149/ffiv-20251015.htm`	2026-11-11	Confirmed
80	Google GTIG, Oracle E-Business Suite zero-day exploitation and extortion, 9 Oct 2025	cloud.google.com	2026-11-11	Confirmed
81	Cisco Talos, Static Tundra, 20 Aug 2025	blog.talosintelligence.com	2026-11-11	Confirmed
82	FBI, PSA I-082025-PSA, FSB cyber actors exploiting networking devices, 20 Aug 2025	ic3.gov	2026-11-11	Confirmed
83	Snyk, Weaponizing AI coding agents for malware in the Nx malicious package, Aug 2025	snyk.io	2026-11-11	Reported
84	Nx (nrwl), security advisory GHSA-cxm3-wv7p-598c, Aug 2025	github.com	2026-11-11	Confirmed
85	NSA, CISA, FBI and partners, AA25-239A, Chinese state-sponsored actors compromising networks worldwide, 27 Aug 2025, revised 3 Sep	cisa.gov	2026-11-11	Confirmed
86	MITRE ATT&CK, G1045 Salt Typhoon (live page, v2.0, modified 23 Sep 2026)	attack.mitre.org	2026-11-11	Confirmed
87	Microsoft Threat Intelligence, Storm-0501's evolving techniques lead to cloud-based ransomware, 27 Aug 2025	microsoft.com	2026-11-11	Confirmed
88	JLR, Statement on cyber incident, 2 Sep 2025	media.jaguarlandrover.com	2026-11-11	Confirmed
89	Snyk, npm supply chain attack via open source maintainer compromise, Sep 2025	snyk.io	2026-11-11	Reported
90	FBI, FLASH-20250912-001, UNC6040 and UNC6395 compromising Salesforce instances, 12 Sep 2025	ic3.gov	2026-11-11	Confirmed
91	SonicWall, MySonicWall cloud backup file incident, 17 Sep 2025, updated 28 Oct 2025	sonicwall.com	2026-11-11	Confirmed
92	US DOJ, United Kingdom national charged in connection with multiple cyber attacks (Thalha Jubair), 18 Sep 2025	justice.gov	2026-11-11	Confirmed
93	Fortra, Security advisory FI-2025-012 (GoAnywhere MFT, CVE-2025-10035), 18 Sep 2025	fortra.com	2026-11-11	Confirmed
94	Microsoft Threat Intelligence, Investigating active exploitation of CVE-2025-10035 GoAnywhere Managed File Transfer vulnerability, 6 Oct 2025	microsoft.com	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
95	RTX, Form 8-K, filed 24 Sep 2025	`https://www.sec.gov/Archives/edgar/data/101829/000010182925000036/rtx-20250919.htm`	2026-11-11	Confirmed
96	CISA, Widespread supply chain compromise impacting npm ecosystem, 23 Sep 2025	cisa.gov	2026-11-11	Confirmed
97	CISA, AA25-266A, incident response at a federal civilian agency (GeoServer CVE-2024-36401), 23 Sep 2025	cisa.gov	2026-11-11	Confirmed
98	CISA, Emergency Directive 25-03, Identify and mitigate potential compromise of Cisco devices, 25 Sep 2025, with the April 2026 update	cisa.gov	2026-11-11	Confirmed
99	Cisco, Continued attacks against Cisco firewalls (event response), first published 25 Sep 2025, updated 5 Nov 2025	sec.cloudapps.cisco.com	2026-11-11	Confirmed
100	Cisco, Security advisory cisco-sa-asaftd-webvpn-z5xP8EUB (CVE-2025-20333), first published 25 Sep 2025	sec.cloudapps.cisco.com	2026-11-11	Confirmed
101	Cisco Talos, ArcaneDoor: new espionage-focused campaign found targeting perimeter network devices (with the 25 Sep 2025 update)	blog.talosintelligence.com	2026-11-11	Confirmed
102	UK NCSC, Persistent malicious targeting of Cisco devices, 25 Sep 2025	ncsc.gov.uk	2026-11-11	Confirmed
103	Anthropic, disrupting an AI-orchestrated espionage campaign, 13 Nov 2025	anthropic.com	2026-11-11	Confirmed
104	Red Hat, Security update: incident related to Red Hat Consulting GitLab instance, 2 Oct 2025	redhat.com	2026-11-11	Confirmed
105	Discord, Update on security incident involving third-party customer service, 3 Oct 2025, updated 9 Oct	discord.com	2026-11-11	Confirmed
106	Oracle, Security Alert CVE-2025-61882 (Rev 1, 4 Oct 2025; Rev 2, 6 Oct 2025)	oracle.com	2026-11-11	Confirmed
107	CVE Program, CVE-2025-61882 record	cve.org	2026-11-11	Confirmed
108	NVD, CVE-2025-61882 (API record)	services.nvd.nist.gov	2026-11-11	Confirmed
109	UK NCSC, NCSC Annual Review 2025 (collection page), 14 Oct 2025	ncsc.gov.uk	2026-11-11	Confirmed
110	UK NCSC, NCSC Annual Review 2025 (PDF)	ncsc.gov.uk	2026-11-11	Confirmed
111	CISA, Emergency Directive 26-01, Mitigate vulnerabilities in F5 devices, 15 Oct 2025	cisa.gov	2026-11-11	Confirmed
112	F5, Lessons we are learning from our security incident (CISO post), 22 Oct 2025	f5.com	2026-11-11	Confirmed
113	CERT-EU, Security Advisory 2025-040 (WSUS CVE-2025-59287), 24 Oct 2025	cert.europa.eu	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
114	NVD, CVE-2025-59287, CVE-2025-10035, CVE-2025-24813 and CVE-2025-31324 (API record for CVE-2025-59287 shown)	services.nvd.nist.gov	2026-11-11	Confirmed
115	UNODC, United Nations Convention against Cybercrime	unodc.org	2026-11-11	Confirmed
116	Google GTIG, Threat actor usage of AI tools, 5 Nov 2025	cloud.google.com	2026-11-11	Confirmed
117	Europol, End of game for cybercrime infrastructure: 1,025 servers taken down, 13 Nov 2025	europol.europa.eu	2026-11-11	Confirmed
118	UK government, Cyber Security and Resilience Bill (collection page), Nov 2025	gov.uk	2026-11-11	Confirmed
119	CISA, Update: implementation guidance for Emergency Directive on Cisco ASA and Firepower device vulnerabilities, 12 Nov 2025	cisa.gov	2026-11-11	Confirmed
120	FBI, CISA and partners, AA24-109A, #StopRansomware: Akira, updated 13 Nov 2025	cisa.gov	2026-11-11	Confirmed
121	US Treasury, sanctions on Media Land (with Australia and the UK), 19 Nov 2025	home.treasury.gov	2026-11-11	Confirmed
122	GitLab, GitLab discovers widespread npm supply chain attack, 24 Nov 2025	about.gitlab.com	2026-11-11	Confirmed
123	React team, Critical security vulnerability in React Server Components, 3 Dec 2025	react.dev	2026-11-11	Confirmed
124	CISA, NSA and Canadian Centre for Cyber Security, AR25-338A, BRICKSTORM malware analysis report, 4 Dec 2025	cisa.gov	2026-11-11	Confirmed
125	Cisco Talos, UAT-9686 targets Cisco AsyncOS, 17 Dec 2025	blog.talosintelligence.com	2026-11-11	Confirmed
126	CISA and partners, AA25-343A, pro-Russia hacktivists target operational technology, last revised 18 Dec 2025	cisa.gov	2026-11-11	Confirmed
127	FBI, PSA update on impersonation of senior US officials, 19 Dec 2025	ic3.gov	2026-11-11	Confirmed
128	NVD, CVE-2025-0282, CVE-2025-20333, CVE-2025-20362 and CVE-2025-5777 (API record for CVE-2025-0282 shown)	services.nvd.nist.gov	2026-11-11	Confirmed
129	NVD, CVE API 2.0 (records with a 2025 published date, queried by quarter)	services.nvd.nist.gov	2026-11-11	Confirmed
130	Google GTIG, 2025 zero-day review, 5 Mar 2026	cloud.google.com	2026-11-11	Confirmed
131	FBI IC3, 2025 Internet Crime Report (PDF)	ic3.gov	2026-11-11	Confirmed
132	TeamStarWolf library, `data/attack/superseded_by.jsonl`	github.com/TeamStarWolf/TeamStarWolf	2026-11-11	Demonstrated

#	Source	URL	Opened	Grade
133	TeamStarWolf library, `data/attack/technique_profiles.jsonl` and the pages under `mitre/techniques/`	github.com/TeamStarWolf/TeamStarWolf	2026-11-11	Demonstrated
134	TeamStarWolf library, `data/attack/groups.jsonl`, `software.jsonl`, `campaigns.jsonl` and `campaign_profiles.jsonl`, and the pages under `mitre/groups/`, `mitre/software/` and `mitre/campaigns/`	github.com/TeamStarWolf/TeamStarWolf	2026-11-11	Demonstrated
135	TeamStarWolf library, `data/weaknesses/cwe.jsonl`, `data/weaknesses/capec.jsonl` and the CAPEC pages under `mitre/capec/`	github.com/TeamStarWolf/TeamStarWolf	2026-11-11	Demonstrated
136	TeamStarWolf library, `data/attack/technique_to_d3fend.jsonl`, `data/attack/d3fend_countermeasures.jsonl` and the pages under `mitre/d3fend/`	github.com/TeamStarWolf/TeamStarWolf	2026-11-11	Demonstrated
137	TeamStarWolf library, `data/attack/mobile/technique_profiles.jsonl`	github.com/TeamStarWolf/TeamStarWolf	2026-11-11	Demonstrated
138	TeamStarWolf library, `navigator/library-layers/` and `case-studies/SHAREPOINT_TOOLSHELL_2025.md`	github.com/TeamStarWolf/TeamStarWolf	2026-11-11	Demonstrated
139	TeamStarWolf library, `data/attack/ics/technique_profiles.jsonl`	github.com/TeamStarWolf/TeamStarWolf	2026-11-11	Demonstrated

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Notable Incidents, Threat Actors, Malware Families, CVE Reference
- CWE Reference, CAPEC Reference, D3FEND Reference
- Ransomware Defense Reference, Edge Device Security Reference, Cloud Attack Reference, Identity Security Reference, ICS/OT Security Reference, Supply Chain Security, Vulnerability Prioritization Reference, AI Security Reference
- Home studies: The SharePoint ToolShell mass exploitation; npm supply-chain attacks; AI threats; China-attributed actors; Russia-attributed actors; Iran-attributed actors; North Korea-attributed actors; ICS attacks and advisories, 2024 to 2026; Zero-day market events; The Ransomware Ecosystem; SSHole: the

OpenSSH authentication bypass

- Related studies: APT41: the public record; Stuxnet; Log4Shell; SolarWinds and SUNBURST; Hugging Face supply chain; The Cl0p MOVEit breach and the file-transfer extortion playbook; Exchange Marauder, 2021; Sandworm; Change Healthcare, 2024; The eMudhra certificate authority compromise
- Series: 2016, 2017, 2018, 2019, 2020, 2021, 2022, 2023, 2024
- Groups: G1045 Salt Typhoon, G0125 HAFNIUM, G0027 Threat Group-3390, G0128 ZIRCONIUM, G1048 UNC3886, G0007 APT28, G0010 Turla, G0035 Dragonfly, G1015 Scattered Spider, G1057 ShinyHunters, G1053 Storm-0501, G1051 Medusa Group, G1040 Play, G1024 Akira, G1032 INC Ransom
- Campaigns: C0058 SharePoint ToolShell Exploitation, C0059 Salesforce Data Exfiltration, C0056 RedPenguin, C0062 Anthropic AI-orchestrated Campaign, C0063 2025 Poland Wiper Attacks, C0046 ArcaneDoor
- Software: S9013 DRYHOOK, S9014 PHASEJAM, S9024 SPAWNCHIMERA, S9012 TRAILBLAZE, S9011 BRUSHFIRE, S9015 BRICKSTORM, S9008 Shai-Hulud, S9035 LAMEHUG, S1213 Lumma Stealer, S1244 Medusa Ransomware, S1162 Playcrypt, S1129 Akira, S1242 Qilin, S1139 INC Ransomware, S1212 RansomHub, S1202 LockBit 3.0, S1073 Royal, S0611 Clop, S1039 Bumblebee, S1160 Latrodectus, S0650 QakBot, S0266 TrickBot, S0357 Impacket, S0002 Mimikatz, S0508 ngrok, S0029 PsExec
- Techniques: T1190 Exploit Public-Facing Application, T1199 Trusted Relationship, T1566.004 Spearphishing Voice, T1598.004 Spearphishing Voice, T1684.001 Impersonation, T1528 Steal Application Access Token, T1213.004 Customer Relationship Management Software, T1671 Cloud Application Integration, T1195.001 Compromise Software Dependencies and Development Tools, T1542.001 System Firmware, T1602.002 Network Device Configuration Dump, T1505.003 Web Shell, T1484.001 Group Policy Modification, T1486 Data Encrypted for Impact, T1485 Data Destruction, T1685 Disable or Modify Tools
- CAPEC: CAPEC-586, CAPEC-115, CAPEC-242, CAPEC-540, CAPEC-100, CAPEC-248, CAPEC-442, CAPEC-650, CAPEC-21, CAPEC-98, CAPEC-532, CAPEC-94
- Navigator layers, including this study's layers, chronicle-2025.json and chronicle-2025-ics.json